СИСТЕМА ЭЛЕКТРОННОЙ ПОДАЧИ ЗАЯВОК «БЮРО ПРОПУСКОВ»

КОНФИДЕНЦИАЛЬНО

ТЕХНИЧЕСКОЕ ОПИСАНИЕ СИСТЕМЫ

Назначение, возможности, устройство и защита информации

Версия документа: 1.92

Дата: 10.11.2026

© 2026 Правообладатель. Все права защищены.

УСЛОВИЯ ИСПОЛЬЗОВАНИЯ ДОКУМЕНТА

Правообладатель: Правообладатель

1. Правообладатель. Исключительное право на настоящий документ и на описанную в нём систему, включая её исходный код и интерфейсы, принадлежит правообладателю. Передача документа не влечёт перехода к Получателю прав на систему или её составные части.

2. Передача третьим лицам. Документ, его части и производные материалы - копии, выдержки, переводы, презентации, снимки экрана - не передаются третьим лицам без согласия правообладателя. Внутри организации Получателя документ доводится до работников, которым он необходим для работы с системой.

3. Отсутствие лицензии. Документ описывает систему и не является офертой или лицензией на её использование. Право использования системы возникает на основании отдельного договора с правообладателем.

© 2026 Правообладатель. Все права защищены.

СОДЕРЖАНИЕ

1. Общие сведения.....5
1.1. Назначение документа.....5
1.2. Состав документации.....5
1.3. Область применения.....6
1.4. Оформление.....6
2. Термины и сокращения.....6
3. Назначение системы.....7
3.1. Решаемые задачи.....7
3.2. Границы применения.....8
4. Пользователи системы.....8
4.1. Типы учётных записей.....8
4.2. Разграничение доступа.....9
5. Жизненный цикл заявки.....12
5.1. Порядок обработки.....12
5.2. Проверка по чёрным спискам.....16
5.3. Прозрачность обработки.....18
6. Функциональные возможности.....20
6.1. Файловый архив бланков.....22
6.2. Уведомления.....27
6.3. Массовый ввод участников из бланка.....32
7. Поиск и работа с накопленными данными.....34
7.1. Поиск, устойчивый к способу ввода.....34
7.2. Приведение сведений к единому виду.....37
7.3. Повторное использование ранее заведённых сведений.....37
7.4. Скорость поиска при накоплении данных.....37
8. Обучение работе с системой.....38
8.1. Обучающие туры.....38
8.2. Встроенное руководство.....40
8.3. Сообщение о сбое.....41
9. Устройство системы.....41

9.1. Состав частей.....41
9.2. Технологическая основа.....43
9.3. Фоновые задачи.....43
10. Организация данных.....46
10.1. Состав базы данных.....46
10.2. Сохранность исторических сведений.....48
10.3. Поиск по большим объёмам.....49
11. Программный интерфейс.....49
12. Обновление данных без перезагрузки.....52
13. Защита информации.....53
13.1. Проверка подлинности.....53
13.2. Разграничение доступа.....59
13.3. Вход от имени другого работника.....60
13.4. Защита передаваемых данных.....62
13.5. Защита от типовых атак.....62
13.6. Защита персональных данных при хранении.....64
13.7. Учёт обращений к персональным данным.....67
13.8. Согласия на обработку персональных данных.....68
13.9. Журналы и прослеживаемость.....72
13.10. Автоматический контроль защищённости.....74
14. Тестирование и обеспечение качества.....75
14.1. Уровни тестирования.....75
14.2. Что дают тесты при сопровождении.....76
14.3. Автоматический конвейер сборки и проверки.....77
14.4. Проверочный стенд.....79
15. Масштаб системы.....79
Приложение А. Категории прав доступа.....81

1. Общие сведения

1.1. Назначение документа

Документ описывает систему электронной подачи заявок «Бюро пропусков»: какие задачи она решает, как устроена работа пользователей, из каких частей состоит и какими средствами защищены обрабатываемые в ней сведения.

Документ предназначен для знакомства с системой перед вводом в эксплуатацию и для понимания её устройства в целом. Порядок установки и сопровождения вынесен в отдельный документ, «Руководство по развёртыванию и сопровождению».

1.2. Состав документации

Таблица 1.1 — Состав эксплуатационной документации

Документ	Кому адресован	Содержание
Техническое описание системы	Руководители, специалисты ИТ и защиты информации	Настоящий документ: назначение, возможности, устройство, защита информации
Руководство по развёртыванию и сопровождению	Подразделение информационных технологий	Требования, установка, настройка, эксплуатация, диагностика
Руководство пользователя	Заявитель	Подача заявок, свои справочники, личный кабинет
Руководство согласующего	Работник, чьё решение требуется для одобрения заявки	Рассмотрение заявок, решение по согласованию, вопросы заявителю
Руководство принимающего	Сотрудник бюро пропусков, ведущий заявки	Приём заявки в работу, назначение постов и мест, дополнения
Руководство администратора	Сотрудник бюро пропусков с правами администратора	Учётные записи, права, справочники, таблицы постов, аудит
Руководство охранника	Сотрудник поста	Работа с таблицами поста, отметка прохода, проверка пропуска

Описание программного интерфейса доступно при включённом SWAGGER_ENABLED. Оно формируется из аннотаций кода; при интеграции контракт дополнительно сверяют с действующим маршрутом и ответом сервера.

1.3. Область применения

Система предназначена для организации пропускного режима на территории предприятия: оформления, согласования и учёта заявок на проход людей, проезд транспорта, внос и вынос материальных ценностей, а также для контроля фактического нахождения людей и транспорта на территории.

1.4. Оформление

Команды, имена файлов и параметры набраны моноширинным шрифтом. Таблицы, рисунки и примеры команд нумеруются по разделам. Угловые скобки означают подстановку: `<домен>` заменяется фактическим значением без скобок.

Отдельно выделяются сведения, требующие повышенного внимания:

ПРИМЕЧАНИЕ. Так оформляются пояснения, которые полезно знать, но которые не влияют на порядок действий.

ВАЖНО. Так оформляются сведения, пропуск которых приведёт к неверной работе или к лишней работе по исправлению.

ОПАСНО. Так оформляются действия, последствия которых необратимы: утрата данных или утрата доступа к ним.

2. Термины и сокращения

Таблица 2.1 — Термины, применяемые в документе

Термин	Значение
Заявка	Электронный документ на доступ на территорию: кто проходит, что проезжает, что вносится, на какой срок и куда
Вложение	Часть заявки, объединяющая однородные объекты: людей, транспорт либо материальные ценности. В одной заявке их может быть несколько, с разными сроками и местами
Бланк	Печатная форма по заявке, заполняемая системой по загруженному шаблону электронной таблицы
Пост, проходная	Точка контроля доступа, за которой закреплены перечни допущенных объектов
Таблица поста	Настраиваемый перечень допущенных людей либо транспорта, с которым работает охрана

Продолжение таблицы 2.1

Термин	Значение
Место разгрузки	Площадка, к которой привязывается вложение заявки на внос или ввоз ценностей
Чёрный список	Перечень людей и транспорта, которым доступ запрещён
Территориальный статус	Признак нахождения человека или транспорта на территории, изменяется отметками въезда и выезда
Согласующий	Работник, чьё решение требуется для одобрения заявки
Принимающий	Работник бюро, принявший заявку в работу и отвечающий за её обработку
Супер-администратор	Единственная учётная запись с полным доступом, включая режим технических работ
Персональные данные	Сведения о людях: фамилия, имя, отчество, документ, удостоверяющий личность, гражданство
Маркер доступа	Электронный пропуск в саму систему: короткая строка, которую браузер прикладывает к каждому обращению вместо повторного ввода пароля. Действует 15 минут, затем продлевается автоматически
Сертификат	Электронный документ, которым сервер подтверждает браузеру свою подлинность. Обеспечивает работу по защищённому соединению, тот самый «замок» в адресной строке
Поток событий	Механизм, которым сервер сообщает открытым страницам об изменениях, чтобы данные обновлялись без нажатия кнопки обновления

3. Назначение системы

3.1. Решаемые задачи

Система предназначена для ведения пропускного режима в электронном виде: оформления заявок на доступ, их согласования, учёта фактического прохода и хранения связанных сведений.

Таблица 3.1 — Задачи, решаемые системой

Задача	Как решается
Передача заявки между участниками	Заявка доступна бюро сразу после отправки. Согласующие работают с ней в системе, передавать документ физически не требуется
Отслеживание состояния заявки	Заявитель видит текущий статус и историю изменений, не обращаясь к бюро
Сохранность сведений	Заявки и история сохраняются в базе; доступ к ним зависит от текущих прав и сроков хранения. Состояние справочника не заменяет проверку сохранности связанных данных

Продолжение таблицы 3.1

Задача	**Как решается**
Поиск по накопленным данным	Поиск по части слова, с учётом раскладки клавиатуры и латинского написания. Подробнее в разделе 7
Единая картина по всем постам	Посты работают с общими данными. Отметка о въезде видна остальным без задержки
Учёт обращений к персональным данным	Каждое обращение записывается в отдельный журнал. Подробнее в подразделе 13.7
Контроль запретов на доступ	Объекты заявки сверяются с чёрными списками при подаче, в том числе с учётом подмены символов. Подробнее в подразделе 5.2
Защита от повторов во вложении	Один человек и одна машина попадают во вложение только раз: повтор отклоняют и форма подачи, и сервер. Подробнее в разделе 6

3.2. Границы применения

Система обеспечивает оформление, согласование и учёт доступа. Она не управляет исполнительными устройствами: шлагбаумами, турникетами и замками. Отметка о проходе вносится работником поста.

4. Пользователи системы

4.1. Типы учётных записей

В системе заведено 6 типов учётных записей. Тип носит справочный характер и служит для классификации работников. Он не определяет, что работник может делать: объём полномочий задаётся ролями и группами прав, поэтому два работника одного типа могут иметь разный доступ, а работники разных типов - одинаковый.

Единственное, на что тип влияет напрямую, - круг получателей заявки: работника с типом «Руководитель» вправе выбрать получателем любой заявитель, в какой бы организации тот ни работал. Подробнее в подразделе 4.2.

Таблица 4.1 — Типы учётных записей

Тип
Пользователь
Арендатор
Подрядчик
Охранник
Руководитель
Бюро пропусков

Типы создаются и редактируются администратором, перечень не является закрытым.

> **ПРИМЕЧАНИЕ.** Настройку системы через интерфейс (справочники, таблицы постов, права, учётные записи) ведут сотрудники бюро пропусков под учётной записью с соответствующими правами. Порядок этих действий описан в руководстве администратора.

4.2. Разграничение доступа

Права вычисляются по четырёхуровневой модели. Уровни рассматриваются по порядку, первый подходящий определяет результат.

1. Заблокированному работнику закрыты служебные и чужие данные независимо от назначенных ролей. Предусмотренное чтение собственных данных проверяется отдельно; блокировка не означает их удаления.
2. Супер-администратор имеет полный доступ, включая режим технических работ и назначение прав администратора. Такая учётная запись в системе одна, это ограничение поддерживается принудительно.
3. Администратор имеет полный доступ, кроме действий супер-администратора и кроме персональных запретов.
4. Обычный работник получает права из назначенной роли, групп прав этой роли и персонально назначенных групп. Затем применяются персональные исключения, причём запрет имеет приоритет над разрешением.

Приоритет запрета позволяет закрыть конкретному работнику отдельное действие, не разрушая назначенную ему роль и не создавая роль на одного человека.

Каталог прав содержит 63 фиксированных ключа в 7 категориях. Дополнительно на каждую созданную таблицу поста автоматически создаётся 10 прав: просмотр, отметка въезда, отметка выезда, карточка объекта, история, версии, выгрузка, отчёт по проходам, корзина, удаление. Заводить права для новой таблицы вручную не требуется.

Разделы администрирования закрыты каждый своим правом, и вложенности между ними нет: право на раздел администрирования само по себе не открывает ни справочники, ни учётные записи, ни настройки, ни журнал обращений к персональным данным, ни файловый архив, ни конструктор таблиц постов, ни мониторинг запросов. Каждое из этих прав назначается отдельно, поэтому работник, ведущий справочники, получает справочники и ничего сверх них. Администраторов и супер-администратора это не касается: они проходят по признаку учётной записи, а не по перечню ключей, и раздельные права круг их возможностей не сужают.

Отдельными правами закрыты действия, которые не сводятся к доступу на экран: выгрузка заявок, согласование, пересылка, дополнение поданной заявки, массовый ввод участников из бланка, выгрузка сведений документов в бланк, блокировка учётной записи, вход в систему от имени другого работника, смена паролей всем работникам. Последнее отделено от права на раздел настроек намеренно: правка контактного телефона бюро и сброс паролей всей организации - действия разного веса, и второе не должно доставаться каждому, кому разрешено первое. Назначаются они независимо от прав на разделы, поэтому круг работников, которым разрешено, например, дополнять свои заявки, задаётся отдельно от круга тех, кто эти заявки видит. Право не отменяет проверок по существу дела: дополнить заявку разрешено её автору, и наличие права на чужую заявку не распространяется - кроме исключений суперадминистратора по области заявки. Самостоятельные

ограничения состояния учётной записи, согласия и выдачи архивных оригиналов сохраняются.

Просмотр документных полей и их выгрузка разделены. Право на раздел «Документы» разрешает читать серию и номер паспорта, патент и другие документные поля; право на выгрузку разрешает включать их в бланк только при разрешённом просмотре. Видимость самой записи проверяется отдельно. Заявитель сохраняет доступ к сведениям, которые сам подал в своей заявке, независимо от документных прав и личного запрета просмотра документов. Это исключение не распространяется на чужие заявки и исторические архивные оригиналы. Суперадминистратор имеет доступ с учётом самостоятельных ограничений обработки персональных данных, см. подразделы 6.1 и 13.8.

Скрытые документные поля не стираются при сохранении доступных соседних полей. Если в новую заявку выбран человек из справочника, а его документы заявителю недоступны, обязательные документные сведения можно ввести для этой заявки самостоятельно: скрытое значение не копируется и справочник этим вводом не изменяется.

Право «Вход от имени пользователя» стоит особняком и среди них: оно не открывает ни экрана, ни отдельного действия, а позволяет администратору работать в системе от имени другого работника, не зная его пароля. Что при этом разрешено, что закрыто и как это видно в журнале, описано в подразделе 13.3.

Пересылка требует действующего разрешения и видимости заявки. Участие в заявке само по себе не отменяет запрет пересылки. Получатель, которому доступно только чтение, не получает право назначать ответственных и согласующих. Назначаемый согласующий также должен иметь возможность согласования. Если обязательный согласующий из организации или компании не может согласовать заявку, подача останавливается с просьбой выбрать другого; необязательный добавляется

только для просмотра. Сообщение заявителю не раскрывает персональные запреты и устройство прав.

Для изменения и удаления человека или машины сначала требуется доступ к просмотру записи. Режим «Все записи» расширяет область чтения, но не разрешает менять чужие записи. Список раздела и общий поиск применяют одинаковые ограничения видимости; история имеет собственную проверку доступа.

Отказы в доступе записываются в журнал: работник, запрошенное действие, время. Это позволяет отличить неверно настроенные права от попытки обойти ограничения.

5. Жизненный цикл заявки

5.1. Порядок обработки

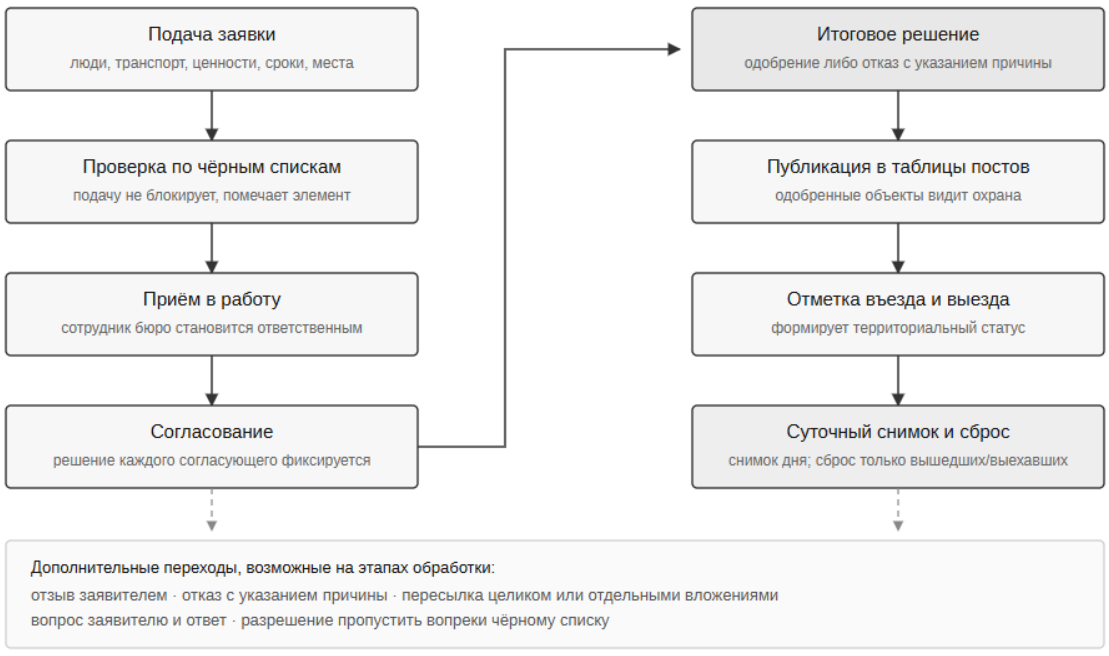


Рисунок 5.1 — Порядок прохождения заявки

Заявитель заполняет заявку: указывает организацию, добавляет вложения по людям, транспорту и ценностям, задаёт сроки и места, при необходимости прикладывает файлы, подтверждает, что указанные лица

уведомлены об обработке персональных данных и сведения переданы правомерно, и отправляет.

При отправке объекты заявки сверяются с чёрными списками. Порядок сверки описан в подразделе 5.2.

Заявка попадает в центр заявок. Сотрудник бюро принимает её в работу и становится ответственным. При необходимости назначаются согласующие, решение каждого фиксируется отдельно. Обработчик может задать заявителю вопрос и получить ответ, не выходя из карточки заявки, а также переслать заявку целиком или отдельными вложениями в другое подразделение.

Круг тех, кому заявку показывают, ограничен и при подаче, и при пересылке. Получателей заявитель выбирает из работников своей организации, работников своей компании и руководителей; тот же круг проверяется на сервере, поэтому назвать получателем постороннего в обход формы нельзя, а лишний идентификатор в запросе отбрасывается, не отменяя подачу целиком. При пересылке ограничение действует так же, кроме супер-администратора и работника бюро, принимающего заявки: маршрутизация заявок по чужим организациям и есть его работа, и круг собственных коллег здесь только помешал бы.

Обязательность согласования устроена по тому же справочнику, но по другому признаку. Обязательным согласующим заявки становится не тот, кого выбрал заявитель, а тот, у кого в карточке организации или компании стоит соответствующая отметка: форма подачи такого выбора вообще не предлагает, она лишь показывает, кто из ответственных отмечен как обязательный, и подаёт заявку с тем составом, который в этот момент прочитан из справочника. Работник, не входящий в состав организации или компании, обязательным согласующим не становится ни при каких условиях, а список, присланный вместе с заявкой в обход формы, сервер только сверяет с составом справочника - назначить им обязательность нельзя, для этого список и не предназначен. При расхождении заявка не создаётся с урезанным

составом согласующих: подача отклоняется целиком, и заявитель получает отказ вместо заявки, поданной не в том виде, в каком он её отправлял.

Здесь и разница с получателями заявки, о которых сказано абзацем выше. Лишнего получателя система отбрасывает и заявку всё равно подаёт: получатель заявку только просматривает, и один посторонний в списке ничего не решает. С обязательным согласующим так поступить нельзя - он голосует, и от его решения зависит исход заявки, поэтому посторонний в этом списке не отбрасывается молча, а останавливает подачу целиком.

Заявка, застрявшая на согласовании, не теряется: если решения ждут дольше заданного срока, система сама напоминает молчащему согласующему уведомлением и повторяет напоминание с заданной периодичностью. Оба срока и само напоминание задаются в разделе «Настройки». Доступ к нему закрыт отдельным правом: администраторы получают его вместе с остальными правами администрирования, а конкретному работнику оно снимается персональным запретом - так общесистемные значения отделяются от ведения справочников, не заводя ради этого отдельной роли. По умолчанию первое напоминание уходит через трое суток и повторяется каждые трое. Когда у заявки есть обязательные согласующие, напоминания получают только они - голос остальных на исход всё равно не влияет.

После завершения обработки одобренные объекты попадают в таблицы соответствующих постов и становятся видны охране. Работник поста отмечает фактический въезд и выезд, эти отметки формируют территориальный статус и историю проходов.

Уже поданную заявку разрешено дополнить, не подавая новую: заявитель добавляет людей, транспорт или ценности в существующее вложение. Дополнение закрыто отдельным правом: подать заявку может любой работник системы, а добавить в уже поданную - только тот, кому это право назначено. Одного права при этом мало, дополнить можно лишь собственную заявку; исключение - супер-администратор, для него

исключается ограничение по авторству. Остальные условия действительности заявки и вложения сохраняются. Сама заявка должна оставаться действующей: непрочитанную, взятую в обработку и находящуюся в работе дополнить можно, завершённую, отклонённую и отозванную нельзя. Нельзя добавить и в то вложение, чей срок уже истёк. Одновременно по заявке идёт не больше одного дополнения; следующее подаётся после решения по предыдущему.

Дальше порядок расходится надвое, и разделяет его то, выпущены ли объекты заявки на посты. Пока заявка не принята в работу, на проходной по ней никого нет, и добавленное просто становится частью её состава: решения согласующих отменяются, круг согласования начинается заново, теперь уже по дополненному составу. Отдельного решения по такой добавке не выносится, и дальше она ничем не отличается от того, что было подано изначально: когда заявку принимают в работу, добавленные люди и машины встают на посты вместе с исходным составом и попадают в тот же бланк.

Заявку, уже принятую в работу, на повторное согласование не возвращают. Её люди и машины стоят на постах по выданным пропускам, и откат заявки снял бы с проходной всех, кого туда пустили, из-за нескольких добавленных строк. Поэтому добавка проходит собственный круг, отдельный от заявки: согласуют его те же ответственные, что назначены по заявке, а решение выносит принимающий, как и по самой заявке. Статус заявки и её согласование при этом остаются прежними, ранее допущенные люди и машины продолжают проходить по своим пропускам, и работа поста идёт своим чередом.

Строки такого отдельного дополнения до решения по нему на посты не выходят: охрана их не видит, в бланк пропуска они не попадают и в таблицах постов не значатся. Заявителю и согласующим они в карточке заявки видны, но помечены как ожидающие решения. Принятое дополнение выпускает свои строки на посты сразу: они встают в таблицы постов, попадают в бланк вложения и с этого момента видны охране. Отказ принимающего и снятие

добавки самим заявителем закрывают её окончательно, добавленные строки так и остаются недопущенными. Отказ согласующего останавливает добавку, но обратного пути не отрезает: согласующий вправе отозвать свой голос, и тогда круг по добавке открывается заново - при условии, что заявка всё ещё принимает дополнения и другого незакрытого дополнения по ней не появилось. Закрытие самой заявки снимает и незакрытое дополнение по ней, чтобы оно не осталось у согласующих задачей без исхода.

Ход дополнения не остаётся незамеченным. Подача зовёт согласующих, прохождение круга зовёт принимающих, а решение приходит заявителю. Сообщение об исходе дополнения отделено от сообщений о статусе заявки намеренно: статус заявки решением по добавке не двигается, и общее уведомление о заявке ввело бы заявителя в заблуждение.

Ежесуточно в заданное время система сохраняет снимок состояния таблиц. Статусы уже вышедших людей и выехавших машин сбрасываются; статус «На территории» сохраняется, поэтому незакрытый вход не теряется при смене суток.

Подача заявки и дополнения, решения по ним, изменение жизненного цикла и запись обсуждения сохраняют обязательные связанные записи в одной транзакции. Ошибка обязательной связи или истории отменяет соответствующее изменение целиком. Доставка внешнего сообщения после подтверждённого сохранения не является частью этой транзакции: её сбой не означает отмены принятой заявки.

5.2. Проверка по чёрным спискам

Сверка выполняется при отправке заявки и работает на двух уровнях.

Точное совпадение. Если объект заявки совпадает с действующей записью чёрного списка, заявка не принимается, а заявитель получает отказ с пояснением.

Близкое совпадение. Сравнение выполняется не по исходной строке, а по приведённой к единому виду, поэтому обнаруживаются варианты,

которыми точное сравнение обойти легко: подмена русских букв внешне похожими латинскими, замена буквы «О» на ноль в номере, опечатка, отсутствие отчества. Такой объект помечается признаком возможного совпадения с указанием, с какой записью и насколько близко он совпал.

Пометка не блокирует подачу, но **блокирует согласование заявки** до тех пор, пока по каждому помеченному объекту не будет принято явное решение пропустить его вопреки запрету. Пометка действует ровно столько, сколько действует запрет, на который она ссылается: снятая с учёта запись гасит её сама, и заявка согласуется без такого решения. Такое решение фиксируется отдельной записью с указанием принявшего его работника, поэтому ответственность за пропуск персонализирована.

Повторные предупреждения по той же паре «объект и запись чёрного списка» после принятого решения не выводятся.

Решение по помеченному объекту принимает согласующий заявки либо принимающий - кто первым дошёл до заявки; отменить принятое решение вправе оба. Помимо пропуска, у принимающего есть второй путь: убрать объект из поданной заявки, указав причину. Он предусмотрен для случая, когда пропуск неприемлем: без него помеченный объект держал бы заявку целиком, и единственным выходом был бы отказ по ней. Объект при этом перестаёт действовать и уходит из перечней постов, но остаётся в заявке и в её истории - заявка сохраняется как документ.

Внесение объекта в чёрный список действует и на уже оформленные данные: совпадающие люди и транспорт перестают действовать и исключаются из перечней постов, а в заявках остаются с отметкой о запрете. Перед внесением система показывает работнику, где объект фигурирует: сколько действующих записей перестанет действовать, из каких перечней постов они уйдут и в каких заявках встречаются. Перечень считается по тем же правилам, по которым выполняется само исключение.

5.3. Прозрачность обработки

Заявитель в любой момент видит текущее состояние заявки и историю её изменений: когда принята в работу, кто ответственный, какие решения приняли согласующие, по какой причине отказано. Обращаться за этими сведениями к бюро не требуется.

Дополнения заявки прослеживаются так же и в той же истории, отдельного журнала для них нет. Записью отмечается подача дополнения, голос каждого согласующего и отзыв голоса, прохождение круга согласования, принятие, отказ принимающего и снятие добавки. У каждой такой записи проставлен номер дополнения, поэтому в заявке с несколькими добавками видно, к какой из них относится решение. Состав добавки, её автор, пояснение и голоса по ней показаны в карточке заявки отдельным блоком, а сами добавленные строки помечены в составе вложения, и по пометке видно, допущены они уже на посты или ещё ждут решения.

Отметки прочтения ведутся персонально: система различает, кто именно из имеющих доступ работников открывал заявку, а не только факт открытия.

Состав участников заявки виден одним списком: заявитель, работник бюро, принявший её в работу, согласующие с их решениями, ответственные и те, кому заявку открыли на просмотр. На каждом показаны должность, организация и компания, а также рабочие контакты - почта и телефон, - чтобы связаться с человеком по заявке, не запрашивая его адрес у бюро. Список доступен участникам этой же заявки; тому, кто заявку не видит, система отвечает отказом. Работник, не подтвердивший согласие на обработку персональных данных, показан в списке скрытым и без контактов, см. подраздел 13.8.

Перечень заявок за период выгружается из центра заявок в электронную таблицу: номер и дата подачи, организация и компания, заявитель, состояние заявки и её согласования, кто принял в работу, число людей и машин, границы срока действия, отметки чёрного списка и наличие

приложенных файлов. В файл уходит ровно та выборка, что отобрана на экране: заданный период, справочники, состояние, режим архива. Выгрузка закрыта тем же правом, что скачивание бланка одной заявки, и подчиняется тем же границам видимости - работник получает в файле только те заявки, которые видит в системе. Фамилии тех, кто не подтвердил согласие на обработку персональных данных, заменяются в файле именем учётной записи так же, как на экране, см. подраздел 13.8. Обращение к выгрузке учитывается в журнале обращений к персональным данным, см. подраздел 13.7.

Уточнения сроков, пересылки и учёта

Изменение сроков определяется отдельными управляемыми правами, а не названием роли. Заявитель с соответствующим правом может менять доступные сроки в допустимых состояниях; само авторство заявки такого права не даёт. Право на сроки вложений и право на индивидуальный срок человека или машины независимы.

Общий срок можно менять до принятия заявки и в работе при наличии соответствующего права. Индивидуальный срок задаётся конкретному человеку или машине в работающей заявке, а также действующей ручной записи. При общей смене срока интерфейс предлагает сохранить индивидуальные сроки либо применить общее изменение к выбранному составу. Уже поданные голоса сохраняются; следующий согласующий видит новый срок. Изменение и его автор остаются в истории. Завершённая заявка не возвращается в работу простым продлением, просроченная не принимается как действующая.

Пересылка показывает, кому и с каким назначением направлены материалы: просмотр или согласование. Отозванную заявку можно переслать только для просмотра. История содержит состав материалов и комментарий. Для старых записей без идентификаторов получателей выводится «Сведения

о получателях недоступны»: непроверенные имена не восстанавливаются по совпадению текста.

Если срок истёк, а человек или машина ещё числятся на территории, строка остаётся доступной для отметки выхода/выезда; новый вход запрещён. После выхода такая строка остаётся на пять минут. Список незакрытых отметок и административное исправление учёта доступны только администратору и суперадминистратору; для исправления дополнительно нужны действующее право и причина. Отметки старше 48 часов выделяются для внимания администратора. Неизвестное время старого входа показывается явно и не считается автоматически превышением 48 часов. Обычные отметки входа/выхода и обновление сроков у охранника сохраняются. Отзыв, архив и потеря привязки к посту не возвращают охране видимость недоступных данных.

6. Функциональные возможности

Таблица 6.1 — Функциональные подсистемы

Подсистема	**Возможности**
Заявки	Создание, приём в работу, согласование, завершение, отказ, отзыв. Дополнение уже поданной заявки со своим кругом согласования. Пересылка целиком и по вложениям, вопросы и ответы, история статусов, персональные отметки прочтения, напоминания молчащим согласующим
Вложения и бланки	Группировка объектов внутри заявки, настраиваемые дополнительные поля, шаблоны печатных форм с привязкой к ячейкам таблицы, формирование заполненного бланка. В бланк подставляются и сведения соседних вложений той же заявки - материальные ценности и транспорт: в печатной форме на ввоз есть строка под марку и номер машины, а сами машины заявитель заводит в отдельном вложении. Печатаются при этом только строки, допущенные на посты: состав непринятого дополнения в бланк не попадает. Выгрузка бланков в файловый архив на диске. Длинный перечень переносится на следующую страницу вместе со своей шапкой столбцов, поэтому многостраничный бланк остаётся читаемым. Заполненный бланк принимается обратно и наполняет список участников заявки, см. подраздел 6.3
Транспорт	Реестр транспортных средств, привязка к заявкам и постам, отметки въезда и выезда, история проездов, добавление вне заявки
Люди	Реестр физических лиц, документы, гражданство, история проходов, прикрепление файлов

Продолжение таблицы 6.1

Подсистема	**Возможности**
Чёрные списки	Раздельные перечни по людям и транспорту, проверка при подаче, признак возможного совпадения, разрешение пропуска вопреки запрету с фиксацией
Таблицы постов	Конструктор перечней: настраиваемые столбцы, фотографии, временные интервалы, корзина удалённых записей, суточные снимки, выгрузка
Места разгрузки	Справочник площадок, фотографии, расписания, привязка к организациям
Организации и компании	Структура арендаторов и подрядчиков, ответственные лица, привязка ресурсов, групповые операции
Аналитика и отчёты	Панель показателей, конструктор отчётов, сохраняемые шаблоны, сводные таблицы, выгрузка в электронную таблицу
Права доступа	Роли, группы прав, персональные исключения, журнал отказов
Учётные записи	Заведение, блокировка, снятие блокировки входа после неудачных попыток, журнал входов, признак нахождения в системе и давность последнего входа, групповые операции. Смена собственного пароля работником, смена пароля отдельному работнику с отправкой письмом, обновление паролей всем работникам, требование сменить пароль по истечении срока его действия, отбор учётных записей без указанного адреса почты
Принимающие заявки	Перечень работников, которым можно передать заявку в работу, и отображаемое имя, под которым заявитель видит принявшего
Новости и объявления	Публикации с форматированным текстом и изображениями, объявление-баннер на главной
Уведомления	События по заявкам, срокам действия пропуска, учётной записи, новостям и обращениям. Доставляются без обновления страницы, повторы одного события собираются в одну запись, набор настраивается работником под себя. Подробнее в подразделе 6.2
Справочники	Гражданства, марки транспорта, форматы регистрационных знаков, типы вложений, типы работников, документы, режим работы бюро
Обратная связь	Обращения работников со статусами, отправка сообщения о сбое
Обучение	Встроенное руководство по ролям и обучающий тур по интерфейсу. Подробнее в разделе 8
Обработка данных	Документ и текст согласия на обработку персональных данных, его редакция, требование согласия при входе и ход сбора. Подробнее в подразделе 13.8
Сведения о субъекте персональных данных	Поиск человека по документу либо ФИО, проверка состава его данных, участия в заявках и отметок. Записи сопоставляются по документу, не по совпадению имени. Чтение закрыто отдельным правом, выдача справки — дополнительным правом и записью о раскрытии
Журналы и режим работ	Журнал запросов, сводный журнал изменений, журнал обращений к персональным данным, режим технических работ
Файловый архив	Выкладывание сформированных бланков на диск сервера, раскладка файлов, занятое место, ошибки записи, выгрузка задним числом. Подробнее в подразделе 6.1

Одного человека и одну машину вложение принимает только один раз: повтор отклоняют и форма подачи, и сервер. Людей система различает по паспортным данным, а когда шаблон вложения их не запрашивает - по фамилии, имени и отчеству; машины - по государственному номеру, поэтому одна машина под разными марками повтором не станет. Пробелы и регистр букв при сравнении не учитываются. Номер «По факту» конкретную машину не опознаёт, таких строк во вложении может быть несколько, а одно лицо в разных вложениях допустимо: у вложений свои сроки и места прохода.

Файлы до подачи заявки хранятся на сервере как файлы-черновики владельца; текстовый черновик формы отдельно сохраняется в браузере. Ограничение по умолчанию для учётной записи — 50 файлов и 200 МиБ, включая выполняющиеся загрузки из параллельных вкладок. Один файл ограничен 10 МиБ; серверный предел поданной заявки — 30 файлов и 100 МиБ. Текущая форма подачи дополнительно ограничивает выбор 10 файлами: компонент ApplicationFilesUpload использует собственный maxCount и не получает значение серверной настройки. Эти два ограничения нельзя описывать как один автоматически синхронизируемый параметр. Сервер резервирует квоту до записи, поэтому параллельные загрузки не должны обходить общий предел. В форме есть «Файлы-черновики» для просмотра и удаления загруженного до подачи. Удаление может затронуть незавершённую работу в другой вкладке. По истечении срока хранения (по умолчанию 24 часа от загрузки) такие файлы может удалить фоновая уборка; этот срок не распространяется на файлы поданных заявок.

6.1. Файловый архив бланков

Сформированные бланки система сохраняет на диске отдельно от базы данных. Это историческое хранилище, а не общедоступная папка документов: прямой сетевой доступ обходит проверки приложения и не должен использоваться как обычный способ выдачи бланков. Размещение

архива и права операционной системы на него настраиваются отдельно от прав пользователей приложения.

Раскладка задаётся отдельно шаблоном каталогов и отдельно шаблоном имени файла. В них подставляются сведения заявки, поэтому папки складываются в понятную человеку структуру, а не в список номеров. Настраивают раскладку не через интерфейс, а командой на сервере: шаблон определяет, где физически лежат документы со сведениями работников, и его смена переносит дерево заявок целиком, поэтому право на такое изменение отделено от работы в системе и требует доступа к серверу. Команда показывает получающийся путь на примере действующей заявки до сохранения и отклоняет неизвестное обозначение, а само изменение записывает в журнал изменений.

Изначально путь состоит из четырёх уровней - год, месяц, день и папка заявки, в имени которой стоят дата, номер и организация. Имя файла образуют вид вложения и организация. День берётся по местному времени, а не по времени хранения в базе, поэтому вечерняя заявка не уезжает в папку следующих суток. Символы, недопустимые в именах файлов Windows, заменяются читаемыми, а слишком длинное имя папки укорачивается: путь ограничен так, чтобы файл открывался с рабочего места по сети двойным щелчком.

Рядом с бланками кладётся машиночитаемый слепок заявки: поля заявки, все люди, машины и материальные ценности по вложениям, согласования и места разгрузки одним файлом. Он нужен, чтобы сведения заявки можно было передать в другую систему учёта, не разбирая печатную форму.

Туда же уезжают файлы, приложенные к заявке при подаче. Они складываются в отдельную папку внутри папки заявки: имена этих файлов задаёт заявитель, и совпадение с именем бланка перезаписало бы печатную форму. Отдельного срока хранения у них нет - файлы появляются в архиве вместе с заявкой и живут там столько же, сколько она.

Внутри расшифрованных бланка и слепка сведения документов представлены открытым текстом. Сам файл архива при включённом шифровании защищён; для чтения вне системы его сначала расшифровывают ключом получателя. Поэтому каталог архива - хранилище персональных данных того же класса, что и база, и требования к доступу к нему те же. Подробнее в подразделе 13.6.

Выгружаются бланки тех типов вложений, у которых включено автосохранение. Тумблер стоит в карточке типа вложения и недоступен, пока архив выключен целиком или у типа нет действующего бланка.

Файлы обновляются вслед за заявкой: бланк переписывается при подаче, при изменении и по отдельной команде повторной выгрузки. Изменилось ли содержимое, система определяет по контрольной сумме: при совпадении файл не открывается вовсе, поэтому его дата и время остаются прежними и средство синхронизации на рабочий компьютер не переносит его заново. Исправление организации переносит папку целиком, а не заводит рядом вторую.

Запись идёт не в момент нажатия кнопки, а фоновой очередью: изменение заявки ставит её в очередь и будит обработчик, тот пишет файлы отдельно от работы пользователя. Заявка, для которой запись сорвалась по временной причине, откладывается и повторяется позже. Раз в сутки ночью система сверяет свой реестр выгруженных файлов с тем, что действительно лежит на диске, и дописывает пропавшее: так восстанавливаются заявки, чья очередь потерялась вместе с перезапуском сервера. Сверка идёт по недавним заявкам, глубина окна задаётся настройкой; для более ранних предусмотрена выгрузка задним числом за указанный период. Недописанные при сбое файлы убираются, частично записанный бланк на диске не остаётся.

Файлы закрытой заявки со временем замораживаются: дальнейшие правки в системе их уже не касаются. Отсчёт идёт от того момента, когда заявка перестала действовать: у отозванной - от отзыва, у остальных - от последнего дня, на который выписаны её вложения. Срок задаётся

настройкой на сервере, изначально месяц. Смысл в том, что пока заявку могут поправить задним числом, файл обязан следовать за ней, а после - становится документом и больше не меняется.

Занятое место ограничивается двумя порогами. При заполнении сверх заданной доли раздела ответственным за архив уходит предупреждение - один раз на переход через край, а не потоком. Когда свободного места остаётся меньше заданного запаса или архив упёрся в отведённый ему объём, запись останавливается и возобновляется сама, как только место появится. Заявки при этом продолжают приниматься: архив не должен доедать место, нужное самой системе.

Состояние архива видно в отдельном разделе администрирования, и разложено оно так, чтобы отвечать на вопросы дежурного, а не пересказывать устройство хранилища. Обзор показывает занятое место, отдельно число заявок, бланков и машиночитаемых описаний, свободное место на разделе с разбивкой по тому, чем оно занято, момент последней записи, число ошибок и число вложений, оставшихся без шаблона. Ниже архив разложен по месяцам и по типам вложений - видно, что занимает место. Полоса занятости подписывает каждую долю раздела при наведении. Соседняя лента перечисляет записи реестра целиком, с отбором по состоянию и счётчиком очереди: по ней видно и то, что уже записано, и то, что ждёт разбора, а сорвавшимся строкам подписан срок следующей попытки. Там же приведены действующие настройки - раскладка, пороги места и срок заморозки, - и приведены словами, с примером получающегося пути и пояснением, что произойдёт при достижении каждого порога; изменить их из интерфейса нельзя. Отсюда же исправляют ошибки записи и запускают выгрузку задним числом: за выбранный период или для бланков одного типа, когда его шаблон поправили и печатные формы нужно пересобрать.

Каждому бланку отвечает состояние выгрузки: ждёт очереди, записан, сорвался по временной причине, остался без шаблона, остановлен нехваткой

места, потерял вложение. Различаются они не для порядка: временный отказ система повторяет сама, а отсутствие шаблона или места ждёт человека, и в карточке заявки работник видит это состояние рядом с вложением, не заходя в раздел администрирования. Разбор состояний приведён в руководстве по развёртыванию и сопровождению, подраздел 9.6.

Исторические оригиналы выдаются через раздел файлового архива только действующему незаблокированному суперадминистратору при выполнении остальных проверок доступа. Авторство заявки само по себе не открывает оригинал. Доступны отдельный файл, архив заявки и потоковый архив за период; перед выгрузкой за период можно оценить объём. Превышение установленного предела требует сузить период. Перед началом выдачи проверяется возможность открыть все выбранные файлы; частично отправленный поток нельзя отозвать задним числом. Обращения учитываются в журнале доступа к персональным данным, см. подраздел 13.7.

Сохранённые файлы не содержат достаточного набора идентификаторов для надёжной проверки каждого представленного в них пользователя. Поэтому при действующем требовании согласия выдача таких оригиналов закрыта, включая суперадминистратора. При выключенном требовании она также закрыта, если есть неурегулированный отзыв согласия пользователя или возражение на обработку данных человека. Отключение настройки не отменяет зафиксированный отзыв. Ошибка проверки не разрешает выдачу. Эти ограничения относятся к выдаче, а не означают удаление сохранённых исторических файлов. Срок хранения сам по себе не разрешает обработку или выдачу.

Для работы с заявкой формируется актуальный бланк по текущим правам и правилам скрытия сведений. Обычному пользователю не требуется выбирать между историческим оригиналом и новой сборкой. Если безопасная выдача недоступна, приложение сообщает об этом; восстановление идентификаторов по совпадению ФИО не применяется.

Доступ разграничен тремя отдельными правами: увидеть занятое место и перечень файлов может один круг работников, запускать повторную выгрузку и донаполнение - другой, выносить файлы из системы - третий. Раскладка и пороги в этот перечень не входят: они задаются на сервере, и веб-доступ их не меняет ни при каких правах.

Задания записи файлового архива хранятся в базе, включая ревизию требуемого результата, попытки и срок повтора. В затронутых операциях изменение исходных данных и постановка задания фиксируются вместе. Незавершённая сверка архива хранит границу и курсор обхода и продолжается после перезапуска. Новая ревизия не подтверждается результатом старого задания. Выгрузка согласована с обезличиванием и удалением: отменённое задание не должно заново создавать ранее удалённые сведения. Это не меняет установленную политику хранения и не даёт дополнительных прав чтения архивных оригиналов.

6.2. Уведомления

Уведомления собраны в перечне под значком в верхней панели и продублированы в личном кабинете. Приходят они без обновления страницы, а если связь с сервером прервалась - подтягиваются опросом, поэтому пропустить событие из-за разрыва нельзя.

События разложены по пяти направлениям. Заявки: подача, требование согласования, новая заявка, ждущая принятия в работу, передача для просмотра, смена статуса, вопрос и ответ по заявке, ход дополнения, напоминание молчащему согласующему. Сроки и проходы: срок действия пропуска подходит к концу, заявитель отозвал заявку, по заявке отмечен первый проход. Учётная запись: смена пароля, блокировка и разблокировка записи, блокировка входа после неудачных попыток. Новости и обращения: публикация новости и документа, новое обращение обратной связи и ответ по нему. Система: плановые технические работы, восстановление записи из

корзины, заполнение файлового архива, запись справочника на проверке и её разбор, всплеск ошибок сервера.

Поданную заявку ждёт в Центре не только согласующий, но и работник бюро, который берёт её в работу, - ему уходит отдельное извещение. Оно называет номер заявки, организацию и приславшего работника, показывает начало сообщения и перечисляет приложенные файлы по именам: по одному номеру понять, чья заявка и насколько она срочная, нельзя, а по организации и названию накладной - можно.

Набор настраивается работником под себя: в настройках уведомлений направления раскрываются в отдельные события, и ненужное выключается целым направлением или по одному. Уведомления об учётной записи выключить нельзя - о блокировке собственной записи работник должен узнать в любом случае, и это прямо сказано на экране настроек.

Заблокированной и архивной учётной записи уведомления не создаются и на устройство не уходят. Проверка нужна отдельно от настроек доставки: разрешение показывать сообщения даётся браузеру и живёт независимо от сеанса, поэтому отключённый работник продолжал бы получать сообщения по заявкам, хотя войти в систему уже не может. Исключение одно - сообщение о самой блокировке: оно заводится уже после того, как запись отключена, иначе человек не узнал бы причину. Отправку такому работнику вручную система отклоняет ошибкой, а не тишиной: администратор должен видеть, почему уведомление не ушло. Снятие блокировки возвращает доставку без дополнительных действий.

Повторы одного события не заваливают перечень: несколько ответов на один вопрос или несколько передач одной заявки собираются в одну запись со счётчиком, и она поднимается наверх по последнему событию. Разделены только события разных заявок и разных обсуждений. Напоминания согласующим в такую сборку не попадают: у них свой срок повтора, и каждое должно быть заметно отдельно.

Внешние push-уведомления могут приходить и при закрытом сайте, если работник разрешил их браузеру и доставка настроена. Получение зависит от устройства, поддержки браузера, его фонового режима, сети и срока хранения сообщения у службы доставки; накопление и доставку каждого сообщения после включения устройства гарантировать нельзя. Авторитетное состояние заявок проверяют в самой системе. Набор событий задаёт тот же экран настроек, что и для перечня уведомлений: отдельного набора для внешней доставки нет.

Разрешение даётся браузеру, а не входу в систему, поэтому уведомления продолжают приходить и после того, как учётная запись вышла по сроку; нажатие на такое уведомление приводит к форме входа, а после неё - сразу к нужной заявке. Выход из системы вручную отключает доставку на этом устройстве: на общем компьютере следующий работник не должен видеть чужих заголовков.

На поддерживаемых версиях iOS и iPadOS внешние push-уведомления доступны веб-приложению, добавленному на экран «Домой». В обычной вкладке этот способ доставки недоступен. Встроенная инструкция системы предлагает путь через Safari; возможность добавления из другого браузера зависит от его версии и устройства. Сам сайт остаётся доступным без установки, а внешнюю доставку проверяют отдельно на целевом устройстве.

Настройки доставки вне системы требуют ключей, задаваемых при установке (приложение Б руководства по развёртыванию). Пока их нет, раздел честно сообщает, что доставка не настроена, а перечень уведомлений внутри системы работает как обычно.

Запись открывается в отдельном окне. Состав подробностей зависит от текущего доступа: номер заявки, участники и переход к объекту выдаются только при разрешённом чтении. Если доступ или проверяемая связь с событием отсутствует, показывается нейтральное «Есть обновление» без прежнего текста и ссылок. Признак прочтения, число сгруппированных событий и порядок записей сохраняются. Перечень подгружается по мере

прокрутки, отбирается по признаку прочтения, разделён по дням и позволяет отметить прочитанным всё разом.

Сводка push в аналитике показывает состояние на момент запроса, а не за выбранный период. Диаграмма считает сохранённые подписки устройств; её проценты относятся к подпискам. Карточки считают активных пользователей с подпиской: несколько устройств одного пользователя не увеличивают число пользователей. Карточка «Пользователи с push на iPhone/iPad» относится к сохранённым подпискам iOS, а не к последнему входу или всем посещениям с iPhone. Определение платформы приблизительное по браузеру при подключении. Доля активных с подпиской использует число активных пользователей в знаменателе; отсутствие данных показывается прочерком.

Маршрут внешней push-доставки выбирается для каждого запроса. При прямом соединении проверяется фактический адрес назначения, при использовании исходящего прокси — разрешённая служба доставки. Пустой PUSH_ALLOWED_HOSTS за прокси допускает известные службы Google, Mozilla, Microsoft и Apple; непустой список ограничивает оба маршрута. Для нестандартной службы список задаётся явно; значение known включает известные службы вместе с перечисленными адресами. Ошибки доставки не содержат секретных ключей и адресов подписок.

Уведомления в личном кабинете и шапке можно открыть с клавиатуры: Tab выбирает запись, Enter или пробел раскрывает подробности. В окне подробностей и мобильной модальной панели фокус остаётся внутри открытого окна и возвращается на исходную кнопку после закрытия. Escape закрывает только верхнее окно; при открытых подробностях список под ними сохраняется.

События подачи заявки и создания дополнения регистрируются для рассылки в той же транзакции, что и само действие. В PostgreSQL сохраняются идентификаторы события и сущностей, а не копия исходного письма или персональных полей. Фоновый исполнитель разбирает до 25

готовых событий за проход; создание внутренних уведомлений для получателей и отметка обработки события выполняются одной транзакцией. После её подтверждения push и сигнал обновления отправляются без гарантии внешней доставки. При формировании уведомлений заново учитываются действующие настройки и согласие. Неудавшееся событие повторяется с нарастающей паузой до пяти минут; незавершённые задания не отбрасываются только из-за возраста. Завершённый ключ предотвращает повторную рассылку, а физическое удаление заявки удаляет связанные задания.

Внешняя push-доставка использует отдельную очередь в памяти на 1024 задания и ограниченный пул исполнителей; при переполнении, остановке или возрасте задания более 10 минут доставка может быть пропущена с диагностическим учётом. Эта очередь не восстанавливается после перезапуска и не подменяет сохранённые события формирования внутренних уведомлений.

Новые записи уведомлений сохраняют нейтральные заголовок и текст и проверенные серверные ссылки на источник события с ограниченными техническими фактами. Подробности для списка и ответа на отметку прочтения формируются заново из актуальных данных с правами действующего читателя, правилами отображения имён и состоянием согласия. Снимок прежнего текста не используется как запасной источник. При работе от чужого имени применяются полномочия действующего работника, а не владельца сеанса. Исторические, ручные и импортированные записи без доверенной связи показываются нейтрально; импорт не превращает архивные ссылки в доверенные события. Старые тексты не переписываются массово в базе, но не возвращаются как подробности уведомления. Отзыв согласия проверяется отдельно от маски отображения имени и не обходится административной ролью.

Внешний push содержит нейтральное «Есть обновление» и переход в личный кабинет вместо персонального текста или прямой ссылки на объект.

Подробности читаются после входа в самой системе с актуальной проверкой доступа. Уже переданное устройству сообщение нельзя гарантированно отозвать задним числом.

6.3. Массовый ввод участников из бланка

На мероприятие подают списками в сотни и тысячи человек, а форма подачи рассчитана на ввод по одному. Поэтому список принимается файлом: заявитель скачивает из формы пустой бланк, заполняет его привычным образом и загружает обратно, а система разбирает строки и наполняет ими список участников заявки. Дальше заявка подаётся обычным порядком.

Бланк тот же самый, которым система печатает заявку. Отдельного формата для загрузки нет намеренно: чтобы отдать список, не нужно ни искать образец, ни сопоставлять столбцы вручную - система читает файл по той же разметке шаблона, по которой его заполняет. При выдаче в файл вписывается отметка о том, для какого вида пропуска он выдан; она хранится в свойствах документа и продублирована в скрытом листе, поэтому переживает пересохранение в редакторе.

Возможность закрыта отдельным правом, и по умолчанию его нет ни у кого, кроме администраторов. Причина не в нагрузке на сервер: заявитель, который может заполнить форму, должен заполнять форму, а файлом подаются те, у кого список действительно велик. Право открывает и загрузку, и скачивание пустого бланка сразу: иначе человек скачал бы бланк, заполнил его и получил отказ уже при загрузке.

Негодный файл отклоняется целиком, до разбора строк, и каждый отказ объясняется словами и подсказкой, что делать. Проверяются размер и внутренняя подпись файла, а не его расширение; затем отметка вида пропуска - бланк другого вида пропуска называется прямо, с указанием, для какого он выдан и какой подаётся; при отсутствии отметки сверяются подписи столбцов, и сдвинутая разметка означает предложение скачать бланк заново. Пустой список и превышение потолка в две тысячи строк на

файл тоже останавливают разбор: длинный список разбивается на несколько заявок.

Строки внутри годного файла проверяются теми же правилами, что и ручной ввод, и это требование к системе, а не следствие устройства: загрузка файлом не должна быть способом обойти проверку. Обязательность полей берётся из настроек того же вложения, патент требуется по признаку гражданства и по настройке поля, гражданство сопоставляется со справочником, длины полей сверяются с тем, что примет база. Написание имён приводится к единому виду: латинские буквы, набранные вместо русских, заменяются с показом исправленного варианта, а слитно записанное имя разбирается на фамилию, имя и отчество и помечается как требующее проверки. Совпадение с чёрным списком останавливает строку, повторы внутри файла и повторы того, что уже добавлено в заявку, отсеиваются по тем же правилам, по которым система не принимает одного человека дважды при ручном вводе.

Разбор не обрывается на первой негодной строке: чистые строки принимаются, проблемные показываются перечнем с номером строки в файле и причиной отказа, чтобы человек нашёл её у себя. Причину система формулирует сама, целиком, на русском языке. Правка возможна прямо в перечне для тех причин, которые в нём и видны: незаполненное имя, неопознанное гражданство, слишком длинное значение. Совпадение с чёрным списком и повтор так не исправляются, а сведения документов в перечне не показываются вовсе, поэтому и правятся такие строки только через обычную форму.

Места прохода, места разгрузки и таблицы проезда в файле не передаются: их задаёт заявитель на сайте сразу для всего загруженного списка, и без этого выбора список в заявку не добавляется. Тем же порядком ставится отметка об уведомлении работников об обработке персональных данных: колонки под неё в бланке нет, поэтому заявитель подтверждает её один раз на весь загруженный список, и до отметки список в заявку не

уходит. Заблокированная кнопка называет незакрытое требование словами, чтобы человек не искал причину сам. Перечень проблемных строк выгружается в электронную таблицу с теми же причинами, чтобы список можно было исправить в привычном редакторе и загрузить заново.

При подаче и при одном запросе дополнения суммарно по всем его вложениям допускается до 2000 сотрудников, до 2000 машин и до 2000 строк ТМЦ. Виды считаются независимо; прежнее содержимое заявки в этот бюджет не входит. Сервер сохраняет проверки отдельных строк, связей и полномочий при пакетной записи.

7. Поиск и работа с накопленными данными

7.1. Поиск, устойчивый к способу ввода

Поиск рассчитан на быстрый и неаккуратный ввод. По введённой строке система строит несколько вариантов запроса и ищет по каждому.

Таблица 7.1 — Что распознаёт поиск

Ситуация	Пример ввода	Что будет найдено
Часть слова, в том числе из середины	`иван`	Иванов, Иваненко, Селиванов
Ввод в неверной раскладке клавиатуры	`bdfyjd`	Иванов
Различие в регистре	`ИВАНОВ`	Иванов
Номер слитно и раздельно	`а123вс` и `а 123 вс`	А123ВС
Опечатка в фамилии	`Ивонов`	Иванов

Поиск работает по фамилиям, именам и отчествам, номерам заявок, государственным регистрационным знакам, маркам транспорта, наименованиям организаций и мест разгрузки, наименованиям работ, тексту сопроводительных писем и комментариев.

Сквозной поиск проходит по заявкам, людям, транспорту, учётным записям работников, чёрным спискам, справочникам (организации, компании, места разгрузки, таблицы постов, марки, гражданства, форматы номеров), а также по новостям, объявлениям, документам и обращениям обратной связи. Каждый раздел выдачи закрыт тем же правом, что и его страница: работник видит в подсказках только то, что ему и так доступно.

Опечатки распознаются при поиске по фамилиям внутри раздела - в центре заявок и реестрах: сравнение ведётся по близости написания, поэтому «Ивонов» найдёт Иванова. Для остальных полей поиск идёт по фрагменту строки, и опечатка в середине слова результата не даст.

Сквозной поиск опечатки распознаёт тоже: раньше он требовал точного вхождения, и один и тот же запрос в центре заявок срабатывал, а в строке сквозного поиска нет. Сравнение ведётся по той же близости написания и по тому же порогу, что и в центре заявок. Слова короче четырёх символов сравниваются только точно: на трёх символах похожим оказывается почти любое слово. Государственные знаки сравниваются с допуском тоже, но близкие по написанию номера принадлежат разным машинам, и результат стоит сверять глазами. Неверную раскладку клавиатуры и номер, набранный слитно или раздельно, сквозной поиск понимает.

Выбранный результат открывает саму запись, а не только раздел, в котором она лежит. Карточкой раскрываются заявка, работник, транспортное средство, запись чёрного списка, учётная запись, организация, компания, место разгрузки, марка, гражданство, формат номера, таблица системы, обращение обратной связи и новость. Список при этом сужается тем же запросом, по которому запись нашлась, - чтобы она была видна и в перечне за карточкой.

Три частных случая объясняют, почему одного номера записи мало. У чёрного списка адрес перехода называет ещё и вкладку: машины и люди ведутся отдельными перечнями с независимой нумерацией, и без вкладки открылась бы чужая запись с тем же номером. В реестрах работников и транспорта показ расширяется до самой широкой доступной области: поиск ищет по всему, что работнику разрешено, а реестр открывается на своих записях, и найденная чужая в этот отбор не попала бы - список приехал бы пустым. Объявления и документы по-прежнему открываются разделом: на странице новостей показывается только действующее объявление, а документ по нажатию скачивается, поэтому раскрывать там нечего.

Выдача читается без знания того, как поиск устроен. У названия раздела стоит число найденного, ниже - первые пять строк, а остальные раскрываются на месте кнопкой «Показать ещё»: уходить со страницы за собственными результатами не требуется. Раздел отдаёт не больше двадцати строк на один запрос; когда нужного среди них нет, запрос уточняют. Раздел, в котором нашлось точное совпадение, встаёт первым - набравший государственный знак целиком ждёт машину сверху.

Архивные учётные записи из выдачи не убраны: их ищут как раз для того, чтобы восстановить. Но идут они ниже действующих и помечены словами «в архиве» в подзаголовке строки - на установке, где архивных записей больше, чем действующих, однофамильцы иначе вытесняют работающего человека из выдачи целиком. Учётная запись, чей логин набран целиком, встаёт выше однофамильцев. Записи справочников, чёрных списков, новостей и объявлений, убранные в архив, в выдачу не попадают вовсе: искать их незачем, они уже не действуют.

Разделы опрашиваются одновременно, и время каждого ограничено: 800 миллисекунд на раздел и 2 секунды на запрос целиком. Не уложившийся раздел отмечается в ответе как не ответивший, а остальные показываются - поиск отвечает частично, но отвечает. По той же причине длинные тексты (сопроводительное письмо к заявке, полный текст новости, текст обращения) сравниваются только точно, без допуска на опечатку: приблизительное сравнение письма в несколько десятков килобайт стоит дороже всего остального запроса вместе взятого. У коротких полей - фамилий, номеров, названий - допуск сохраняется.

Списки справочников и таблиц, которые фильтруются прямо в браузере, дополнительно распознают латинское написание русского слова: `ivanov` найдёт Иванова. При поиске заявок такое написание не распознаётся.

7.2. Приведение сведений к единому виду

Часть сведений приводится к единой форме автоматически, чтобы одинаковые по смыслу записи не расходились в написании.

- Государственные регистрационные знаки: убираются пробелы и разделители, латинские буквы, внешне совпадающие с русскими, заменяются на русские, ноль и буква «О» приводятся к одному виду.
- Фамилии, имена и отчества: убираются лишние пробелы, приводится регистр, «е» и «ё» считаются одной буквой.
- Наименования организаций: приводится к единому виду организационно-правовая форма и кавычки. Применяется при разборе организаций, поступающих с заявками, и при модерации справочника.

Приведённая форма используется при сверке с чёрными списками и хранится рядом с исходной, поэтому исходное написание не теряется.

7.3. Повторное использование ранее заведённых сведений

Сотрудники и транспортные средства, ранее заводившиеся в системе, хранятся в реестрах. При оформлении заявки их не требуется вводить заново: в форме предусмотрен выбор из реестра.

По кнопке открывается окно со списком ранее заведённых записей, в котором есть собственный поиск и возможность отметить сразу несколько записей. Отмеченные записи добавляются в заявку вместе с ранее указанными сведениями.

7.4. Скорость поиска при накоплении данных

Для полей, по которым ведётся поиск, создано 38 специальных индексов. Они позволяют искать по фрагменту слова, не перебирая таблицу целиком, что уменьшает объём перебора. Время поиска зависит от объёма и

распределения данных, плана запроса и ресурсов; индексы не гарантируют постоянную скорость при любом росте базы.

8. Обучение работе с системой

Система рассчитана на работников без специальной подготовки, поэтому обучение встроено в интерфейс.

8.1. Обучающие туры

Обучение встроено в интерфейс: система подсвечивает элементы и объясняет их назначение прямо на рабочем экране, не отсылая к отдельному пособию.

Туров пять, по кругу задач работника: заявитель, работник поста, согласующий, принимающий и администратор. Набор доступных туров система определяет по правам учётной записи, а не по её типу: один и тот же человек нередко и принимает заявки, и ведёт справочники, поэтому ему доступны оба тура. Работник видит в меню обучения только то, что относится к его работе.

При первом входе запускается ровно один тур - профильный для этой учётной записи. Остальные доступные работник запускает сам, кнопкой «Обучение» на странице «Обзор и новости». Если доступны несколько туров, кнопка открывает список с пометкой о том, какие уже пройдены; если доступен один тур, сразу открывается окно его запуска.

При ручном запуске открывается окно «Обучение работе с системой»: «Пройти сначала», «Продолжить обучение» при сохранённой позиции и выбор главы с кнопкой «Начать с раздела». Просмотр с раздела не засчитывает весь тур. На сенсорном экране переходами управляют видимые кнопки подсказки. Если поверх обучения открыто рабочее окно, подсказка временно уступает ему управление; после закрытия окна обучение продолжается.

Внутри тура работник не привязан к порядку: счётчик шагов открывает список всех шагов по разделам, и с него можно перейти к нужному месту, в том числе на другую страницу.

Тур разбит на главы по разделам системы: подсказка называет главу и её номер, а на последнем шаге главы вместо «Пропустить обучение» предлагает продолжить позже. Место, на котором работник остановился, переживает и перезагрузку страницы, и закрытие вкладки. Тур, оставшийся на экране в момент ухода со страницы, поднимается сам - его никто не закрывал; закрытый руками ждёт, пока человек вернётся через меню обучения, где рядом с ним написано «Продолжить». Позиция хранится в браузере отдельно по каждому работнику и каждому туру и забывается через две недели: вернувшемуся через месяц честнее начать обучение заново.

Прохождение считается отдельно по каждому туру. Работник, прошедший обучение заявителя, не теряет эту отметку, когда его назначают согласующим, и получает новый тур, а не повтор старого.

Тур можно пройти повторно в любой момент. Администратор может снять отметку о прохождении конкретному работнику - как по отдельному туру, так и по всем сразу, например при переводе на другую должность.

Туры версионируются независимо. После существенного изменения интерфейса работникам показывается обновлённый тур той области, которая изменилась; пройденные туры остальных областей это не затрагивает.

Доступные туры и шаги зависят от роли, действующих прав и готовности данных. При изменении доступа состав шагов пересчитывается; сохранённая позиция сопоставляется с идентификатором шага, поэтому счётчик может измениться. Недоступность данных или ошибка перехода не засчитываются как завершение: появляется «Не удалось открыть шаг» с повторной попыткой и возможностью закрыть обучение, сохранив прогресс.

Там, где показывать нечего, тур показывает пример. Пустые списки заявок, машин и сотрудников заменяются снимком экрана, а рассказ про карточку заявки - примерной заявкой прямо в интерфейсе: у работника без

единой поданной заявки список кабинета и карточка наполняются выдуманными данными, и он узнаёт про статус, вопросы и отзыв заявки наравне с остальными. Интерфейс при этом настоящий, подменяется только чтение: пример существует, пока идёт тур, никуда не отправляется и в базу не попадает. По окончании тура следующий же запрос приносит настоящие данные, и пример исчезает сам.

Учебные сцены также показывают карточки Центра заявок в пределах роли согласующего или принимающего. Объяснение «По факту» включено в тур охранника обязательно: если подходящий живой блок недоступен, показывается подписанный учебный пример. Он не открывает недоступный пост и не выполняет отметку проезда. Административное исправление незакрытых проходов в обучение охранника не входит.

Покрытие обучения проверяется по четырём направлениям: защищённые маршруты, пункты меню, ключи каталога прав и действия в явно указанной области интерфейса. Четвёртая проверка пока охватывает только шаблоны раздела «Доступные мне» и компонента отметки исполнения — `AccessibleAttachmentsView.vue` и `AttachmentExecutionMark.vue`. Найденному действию нужна ссылка на существующий шаг либо объяснение пропуска. Другие экраны, вложенные компоненты вне объявленного охвата и изменение смысла прежней команды требуют отдельной проверки; полноту обучения всего интерфейса этот контроль не подтверждает.

8.2. Встроенное руководство

Руководство дополняет короткие туры подробными справочными материалами. Окно **«Руководство»** на странице **«Обзор и новости»** поддерживает пять разделов: для пользователя, охранника, администратора, принимающего и согласующего. Администратор управляет вводным текстом, перечнем пунктов и PDF каждого раздела. Для обновления этих материалов выпуск новой версии программы не требуется.

Сервер применяет одинаковые правила к списку разделов и скачиванию PDF. Для первых трёх разделов действуют права `guide.user`, `guide.guard` и `guide.admin`. Раздел принимающего доступен по назначению принимающим. Раздел согласующего доступен по назначению ответственным за согласование в организации или компании с учётом явного запрета на согласование. При совмещении функций доступны оба раздела. Прямой запрос файла без доступа возвращает `403`.

8.3. Сообщение о сбое

Если работник столкнулся с ошибкой, он может отправить сообщение прямо из системы. Сообщение сохраняется вместе со сведениями о том, что происходило в момент сбоя, и попадает в раздел обратной связи, где обрабатывается со статусами.

Сам экран сбоя работника на себе не запирает: кнопка возврата ведёт на ту страницу, где запрос упал, а не перезагружает экран ошибки. Когда возвращаться некуда - адрес неизвестен или упала сама главная, - остаётся переход на главную страницу.

9. Устройство системы

9.1. Состав частей

Система собрана из отдельных частей, каждая работает в собственном контейнере. Наружу открыта одна из них, обратный прокси. Остальные работают во внутренней сети сервера и с рабочих мест недоступны.

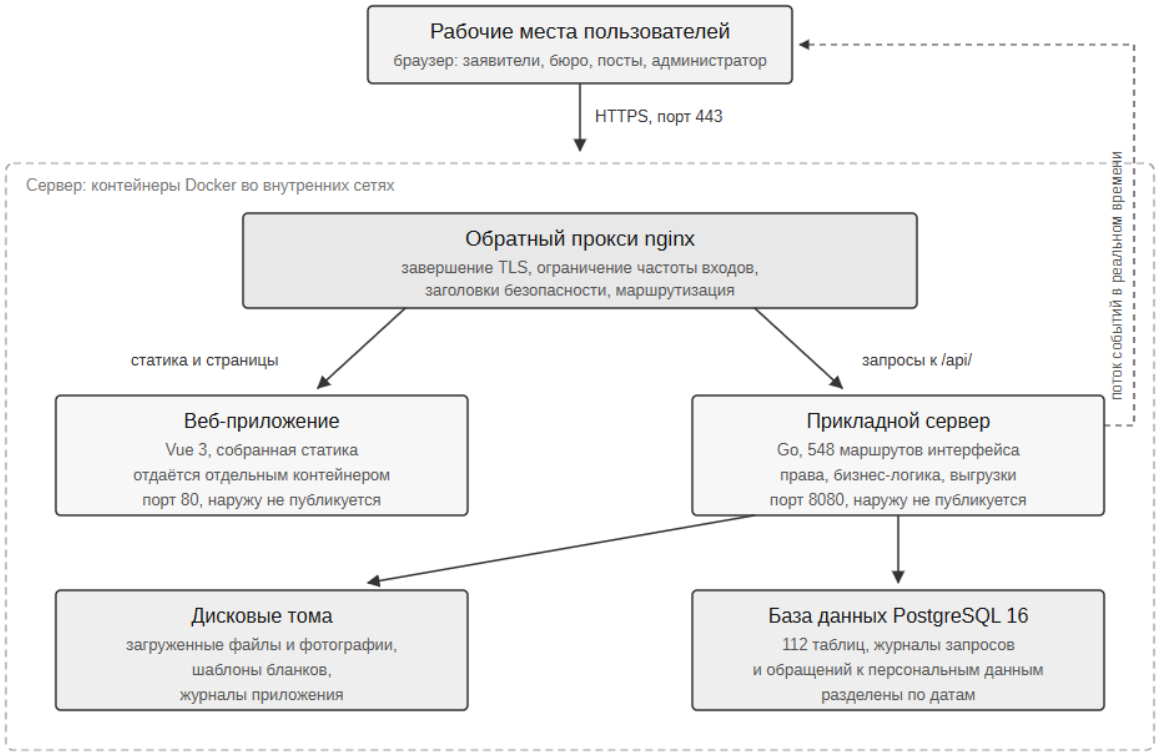


Рисунок 9.1 — Состав системы и потоки данных

Обратный прокси принимает защищённое соединение, расшифровывает его и распределяет запросы: обращения к данным уходят на прикладной сервер, всё остальное отдаёт веб-приложение. Прикладной сервер обращается к базе данных и к хранилищу файлов. Обратный поток событий идёт от прикладного сервера прямо в браузер и обновляет открытые страницы.

Таблица 9.1 — Части системы

Часть	**Основа**	**Роль**
Обратный прокси	nginx	Защищённое соединение, ограничение частоты попыток входа, заголовки безопасности, распределение запросов
Веб-приложение	Vue 3	Интерфейс, с которым работает пользователь в браузере
Прикладной сервер	Go	Проверка прав, обработка заявок, работа с данными, формирование выгрузок
База данных	PostgreSQL 16	Хранение всех сведений системы

9.2. Технологическая основа

Таблица 9.2 — Применённые технологии

Уровень	Технологии
Прикладной сервер	Go (требование исходников 1.26.10, сборочный образ 1.27.3), веб-каркас Echo, работа с базой через GORM и драйвер pgx, формирование электронных таблиц и печатных форм
Веб-приложение	Vue 3.5, хранилище состояния Pinia, сборка Vite, построение диаграмм, редактор форматированного текста
Хранение	PostgreSQL 16 с разделением журнальных таблиц по датам и поиском по фрагментам слов
Развёртывание	Docker и Docker Compose, работа от непривилегированного пользователя

Код страниц и редко используемых окон загружается по мере обращения к ним. Общая оболочка не включает код формы обратной связи: он запрашивается при первом открытии формы. Повторное открытие использует уже загруженный модуль. Это не меняет состав доступных действий и серверную проверку прав.

Перечисленное и всё, на что оно опирается, - библиотеки с открытым исходным кодом. Подавляющее большинство распространяется по разрешительным лицензиям: они не требуют ни оплаты, ни раскрытия кода системы, но требуют сохранять уведомление об авторских правах при передаче программы. Полный перечень компонентов с их версиями, лицензиями и правообладателями входит в поставку отдельным файлом, и в нём же отдельно выделены те немногие, чьи условия сохранением уведомления не исчерпываются. Порядок обращения с перечнем описан в руководстве по развёртыванию и сопровождению, подраздел 4.4.

9.3. Фоновые задачи

Прикладной сервер сам выполняет периодические задачи, отдельный планировщик в операционной системе не нужен.

Таблица 9.3 — Периодические задачи

Задача	Периодичность	Действие
Архивация просроченных вложений	15 минут	Вложения с истёкшим сроком перестают действовать

Продолжение таблицы 9.3

Задача	Периодичность	Действие
Архивация журнала отказов	Сутки	Записи старше 90 суток переносятся в архив
Суточный снимок и сброс	Ежесуточно в 06:00	Сохраняется состояние таблиц постов; сбрасываются статусы уже вышедших/выехавших, незакрытые входы сохраняются
Суточный отчёт по проходам	Ежесуточно в 21:30	Сохраняются итоги проходов и проездов за сутки
Фиксация пика посещаемости	Минута	Записывается наибольшее число одновременно работающих за сутки
Напоминания согласующим	Час	Согласующему, чьё решение ждут дольше заданного срока, отправляется уведомление
Предупреждение об истечении пропуска	Ежесуточно в 09:00	Заявителю дважды сообщается о приближении общего срока заявки - за три дня и накануне; общим сроком считается самая поздняя дата среди её активных вложений
Пересчёт показателей аналитики	60 секунд	Панель открывается сразу, без ожидания расчёта
Обслуживание журнальных таблиц	Сутки	Создание разделов вперёд, свёртка и удаление устаревших
Уборка технического мусора	Сутки	Удаляются недействительные маркеры продления, прочитанные и давние непрочитанные уведомления, подписки устройств без доставки и отработанные записи очереди почты; при отдельно заданном сроке также история сущностей
Обезличивание заявок по сроку хранения	Сутки	startApplicationRetentionWorker: при APPLICATION_RETENTION_MONTHS больше нуля обрабатывает завершённые, отозванные и отказанные заявки; даты, статус и решения сохраняются
Уборка неотправленных файлов заявок	Час	Удаляются файлы, загруженные к заявке, которую так и не отправили, и файлы, потерявшие запись в базе
Уборка результатов команд подачи	Час	startApplicationOperationCleanup: удаляет результаты команд старше 25 часов; до 10 порций по 500 записей и до 10 секунд на проход, заблокированные записи пропускаются

Продолжение таблицы 9.3

Задача	Периодичность	Действие
Проверка сроков действия паролей	Ежесуточно в 04:00	Работникам, у которых срок действия пароля вышел, поднимается требование сменить пароль при следующем входе; тем, у кого срок подходит, заранее уходит предупреждение. Паролей задача не меняет и писем с паролями не рассылает. При выключенном сроке действия задача не делает ничего
Формирование уведомлений о подаче и дополнении	Каждые 2 секунды и по сигналу после сохранения	Обрабатываются сохранённые события; незавершённая работа продолжается после перезапуска
Разбор очереди писем	15 секунд	Накопившиеся письма передаются почтовому серверу, непринятые повторяются с нарастающей паузой. Задача не запускается, если почта не настроена
Выгрузка бланков в файловый архив	15 секунд и сразу при изменении заявки	Разбирается очередь записи файлов на диск
Повтор неудавшихся выгрузок	5 минут	Заявки, чья запись сорвалась по временной причине, выгружаются заново
Сверка файлового архива с диском	Ежесуточно в 03:00	Реестр выгруженных файлов сверяется с содержимым каталога, пропавшее дописывается
Уборка недописанных файлов архива	Час	Удаляются временные файлы, оставшиеся после прерванной записи
Проверка всплеска серверных ошибок	5 минут	Считается доля ответов с кодом 5xx за последние пять минут; когда она переходит 5 процентов при не менее чем 50 запросах в окне, работникам с доступом к разделу мониторинга уходит уведомление. Между уведомлениями выдерживается пауза 30 минут

ПРИМЕЧАНИЕ. Резервное копирование в этот перечень не входит. Его выполняет не прикладной сервер, а отдельный сценарий, который ставится на расписание средствами операционной системы при установке системы: ежесуточное копирование и ежемесячная проверка восстановимости копии. Порядок описан в руководстве по развёртыванию и сопровождению.

Веб-приложение загружает основные страницы при переходе к ним; состояние сессии остаётся общим. Библиотека формирования ZIP подключается при скачивании. Это уменьшает первоначальную загрузку, но

не обещает фиксированного времени открытия: на него влияют сеть, устройство, данные и состояние кэша. Хешированные JS/CSS сжимаются и кэшируются отдельно от HTML; HTML сохраняет подстановку защитного nonce и не хранится как неизменный ресурс.

10. Организация данных

10.1. Состав базы данных

База содержит 116 таблиц по перечню моделей и статических SQL-определений исходного кода: справочники, учётные записи и права, заявки со связанными сущностями, реестры людей и транспорта, таблицы постов, журналы.

Это счётчик схемы в репозитории, не результат запроса к работающей БД; динамические партиции журналов в него не включены.

Дополнения заявки хранятся отдельно от неё самой: одна таблица описывает саму добавку (номер по счёту в заявке, состояние, автор, пояснение и итоговое решение), вторая - голоса согласующих по ней. Состав голосующих записывается в момент подачи добавки и дальше не меняется вслед за заявкой, поэтому решение видно тем же составом, каким оно принималось. Круг согласования добавки отделён от круга самой заявки намеренно: голоса по заявке при этом остаются нетронутыми, а от них зависит допуск на посты уже выданных пропусков.

Строки вложений - люди, транспорт и ценности - хранят признак того, какой добавкой они заведены. У поданных вместе с заявкой он пуст. По этому признаку и определяется, допущена ли строка на посты. Поданные с заявкой и добавленные в её собственный круг согласования допущены наравне: их судьбу решает сама заявка. Строка отдельной добавки допускается её принятием, а до него и при отрицательном решении на посты не выходит. Одно и то же условие применяется и при выдаче состава охране, и при формировании бланка, и при отчётах, поэтому расхождения между тем, что напечатано в бланке, и тем, что видит работник поста, не возникает.

Файлы, приложенные к заявке, лежат на диске сервера, а в базе хранятся только сведения о них: имя, тип, размер, кто загрузил. Прикрепить файл можно лишь в момент подачи, поэтому загрузка идёт до создания заявки: файл ложится на диск и ждёт, пока подача свяжет его с заявкой. Файл, о котором подача так и не сказала, система убирает сама через сутки - заявитель выбрал документы и закрыл форму, не отправив её. Той же уборкой снимаются файлы, потерявшие запись в базе.

Приложенные файлы связаны с заявкой. При удалении заявки сведения о файлах снимаются вместе с ней, потерявшие связь файлы убирает почасовая задача. Отдельно действует обезличивание по сроку хранения: при его включении обработка затрагивает связанные персональные данные и файлы, поэтому сохранность исходных документов нельзя считать бессрочной. До включения срока владелец определяет основание и период хранения, порядок резервирования и восстановления.

Две журнальные таблицы растут быстрее прочих, поэтому физически разделены по датам. Это позволяет удалять устаревшие сведения мгновенно, отбрасывая целый раздел, вместо построчного удаления, которое на больших объёмах занимало бы часы.

Таблица 10.1 — Разделение журнальных таблиц

Журнал	**Разделение**	**Срок хранения**
Журнал запросов	По суткам	Подробные записи 30 суток, далее суточные итоги
Журнал обращений к персональным данным	По месяцам	36 месяцев без свёртки

Остальные служебные записи хранятся построчно. Те из них, что обесцениваются сами, суточная задача удаляет без участия человека: это недействительные маркеры продления сеанса и уведомления, у прочитанных и непрочитанных свои сроки, и задаются они параметрами установки.

История действий над сущностями при AUDIT_RETENTION_MONTHS больше нуля также убирается автоматически; исключения защищают последние отметки прохода и записи

корзины. При нулевом значении автоматическая уборка истории выключена. Суточные слепки таблиц постов и суточные итоги журнала запросов не удаляются автоматически. Они нужны для корзины, отчётов и разбора спорных случаев, поэтому решение об их удалении принимает подразделение ИТ отдельной командой; порядок описан в руководстве по развёртыванию и сопровождению. Объём базы, файлов и журналов контролируется по фактической нагрузке; расчёт срока хранения нельзя основывать на неподтверждённом общем прогнозе роста.

Технические таблицы `archive_export_jobs` и `archive_export_scan_states` хранят задания выгрузки и состояние сверки файлового архива; `notification_intents` — события для формирования уведомлений. В `application_operations` хранятся ключ, отпечаток содержимого и минимальный результат подачи или дополнения. Тело команды и персональные поля формы в эту таблицу не записываются. Результат команды сохраняется отдельно от срока жизни самой заявки: удаление заявки не должно превращать старую команду в новую подачу; технические записи удаляются ограниченной фоновой очисткой после 25 часов.

10.2. Сохранность исторических сведений

Справочники, для которых предусмотрен архив, сохраняют прежние значения для связанных заявок. Это не универсальная корзина: записи реестров людей и машин могут удаляться физически. Для каждой сущности следует учитывать её штатный механизм удаления и историю; доступность персональных сведений дополнительно зависит от политики видимости и обезличивания по сроку хранения. Архивная запись не предлагается при заполнении новых заявок и помечается в старых.

Удалённые строки таблиц постов попадают в корзину, откуда их можно восстановить.

Отдельно от этого работает резервное копирование: ежесуточно снимается выгрузка базы, к ней прилагаются архивы загруженных файлов, копии хранятся по схеме семь суточных, четыре недельных и шесть месячных. Раз в месяц система сама проверяет, что копия разворачивается и содержит данные. Копии шифруются, ключ хранится вне сервера. Порядок настройки и восстановления описан в руководстве по развёртыванию и сопровождению.

История настройки таблиц и сведения об их использовании защищены доступом к конструктору таблиц; чтение конфигурации таблицы для заполнения заявки не открывает её административную историю. История выдаётся страницами: по умолчанию 50 записей, не более 200 за запрос. Для последовательного чтения используются snapshot_max_id и name_mask_revision; список работников фильтра также постраничный. Полная выгрузка проходит все страницы выбранного отбора и прерывается при смене границы или правил отображения имён. Формирование итогового XLSX в браузере требует памяти пропорционально числу выгруженных записей.

10.3. Поиск по большим объёмам

Для поиска по фамилиям, номерам заявок, регистрационным знакам и наименованиям организаций создано 38 специальных индексов. Они позволяют искать по фрагменту слова и с опечатками, не перебирая таблицу целиком, что уменьшает объём перебора. Время поиска зависит от объёма и распределения данных, плана запроса и ресурсов; индексы не гарантируют постоянную скорость при любом росте базы.

11. Программный интерфейс

Обмен данными между браузером и сервером идёт через программный интерфейс. Он же может использоваться для интеграции с другими системами предприятия.

Зарегистрировано 549 методов в 41 группе. Обычные JSON-ответы используют общую оболочку. Потоки файлов, служебные ответы и дополнительные маркеры отказа проверяются по конкретному методу, а не приводятся к JSON безусловно.

Листинг 11.1 — Структура ответа программного интерфейса

```
{
  "success": true,
  "data":    { ... },
  "meta":    { "page": 1, "limit": 20, "total": 137 },
  "error":   ""
}
```

Поле `meta` присутствует у методов, возвращающих постраничные списки: оно сообщает номер страницы, её размер и общее число записей. При ошибке поле `success` принимает значение `false`, а пояснение помещается в `error`.

Без входа в систему отвечают только 7 методов: вход, продление сеанса, перечень типов работников, признак режима технических работ, контактные сведения, поток событий и выгрузка файлового архива за период. Все остальные требуют действующего маркера доступа и проходят проверку прав.

Признак режима технических работ отдаётся вместе с объявленным сообщением, сроками работ и контактами поддержки. Эти сведения публичны по назначению: их читает посетитель, которого система в этот момент не пускает внутрь.

Поток событий и выгрузка архива вынесены из-под проверки маркера по одной причине: браузер не передаёт маркер доступа ни при подключении к потоку, ни при переходе по ссылке скачивания. Вместо маркера предъявляется одноразовый билет. Выдаёт его обычный, защищённый метод - там же проверяются право на выгрузку и допустимый объём. Билет живёт минуту, гасится при первом предъявлении и хранит в себе и учётную запись заказавшего, и границы запрошенного периода, поэтому подставить в ссылку

другой период нельзя. Работник в журнале обращений к персональным данным берётся из билета, то есть выгрузка не остаётся безымянной.

Для выдачи загруженных файлов используются действующая сессия и ограничения конкретного маршрута. Статическая раздача разрешена только для предусмотренных каталогов. Доступ к файлам, приложенным к заявке, дополнительно проверяется по самой заявке и принадлежности файла. Служебные выгрузки и файловый архив не выдаются общей раздачей каталога загрузок. Их методы применяют собственные проверки доступа.

Описание интерфейса формируется из аннотаций исходного кода при сборке. Аннотации могут отставать от реализации; при интеграции проверяют действующий маршрут, обработчик и фактический ответ сервера.

Доступ к файлам, билетам скачивания и длительным потокам согласован с жизненным циклом сессии. При последующем запросе повторно проверяются её актуальность и ограничения действия. Открытые потоки периодически перепроверяют доступ. Уже переданные клиенту байты отозвать нельзя. Временная недоступность проверки приводит к отказу в операции и не означает успешного выхода или продолжения доступа.

Для подачи заявки и дополнения клиент может передать ключ команды. В пределах 24 часов повтор с тем же ключом и содержимым возвращает прежний подтверждённый результат. Ключ связан с владельцем сеанса, действующим работником и видом операции; другое содержимое с прежним ключом отклоняется. Защищённый `POST /api/applications/operations/status` проверяет результат без повторной подачи. Ответ `unknown` означает отсутствие подтверждённого результата, а не доказанный отказ и не разрешение создать новую команду. Совместимость с клиентом без ключа сохраняется, но у такого запроса нет этой защиты от повтора.

12. Обновление данных без перезагрузки

Открытые страницы обновляются сами: новая заявка появляется в центре заявок, отметка о въезде видна другим постам, счётчик непрочитанного меняется без нажатия кнопки обновления.

Применена схема, при которой сервер сообщает только то, какую область следует обновить, но не передаёт сами сведения. Получив сигнал, браузер выполняет обычный запрос, к которому применяются права конкретного работника. Благодаря этому по каналу обновлений невозможно узнать ничего сверх собственных полномочий: он не переносит данные.

Подключение к потоку событий авторизуется одноразовым билетом. Состояние сессии и ограничения запроса повторно проверяются перед событием и при служебном сигнале раз в 25 секунд; при отказе поток закрывается. Отдельно соединение принудительно обновляется примерно через 10 минут. Это обновление не является единственным моментом проверки отзыва доступа.

Предел потока учитывается по владельцу сеанса отдельно от работника, от имени которого он действует: до 8 открытых соединений на владельца и 200 на процесс, до 16 неиспользованных билетов на владельца и 400 на процесс. Билет действует 60 секунд, запись в соединение ограничена пятью секундами. При закрытии освобождаются подписка и связанные ресурсы; остановка сервера завершает потоки. После обрыва браузер подключается с паузой и случайным разбросом, учитывает Retry-After и заново получает текущее состояние. Для предусмотренных случаев недоступности потока используется периодический опрос; отказ в доступе не обходится этим способом.

13. Защита информации

13.1. Проверка подлинности

Таблица 13.1 — Механизмы проверки подлинности

Механизм	Реализация
Хранение паролей	Алгоритм Argon2id, устойчивый к подбору на видеокартах. Пароли в открытом виде не хранятся и не попадают в журналы
Требования к паролю	Настраиваемые минимальная длина и обязательный состав символов. Проверяются на сервере при любой установке пароля
Срок действия пароля	Настраиваемый срок, по истечении которого система требует от работника задать новый пароль и до этого никуда его не пускает
Смена пароля работником	Работник меняет свой пароль сам, подтверждая действие текущим паролем
Запрет повторного использования	Вернуться к любому из десяти последних паролей учётной записи нельзя. Правило действует на все пути смены
Пароль при заведении учётной записи	Придумывается системой и высылается работнику письмом; свой пароль работник задаёт при первом входе
Прекращение сеансов при смене пароля	При собственной смене сохраняется текущая сессия, остальные завершаются. Административный сброс завершает сессии целевой учётной записи
Маркер доступа	Действует 15 минут, подписан отдельным ключом
Продление сеанса	Отдельный маркер сроком 7 суток, передаётся только по защищённому соединению и хранится в браузере файлом cookie, закрытым от сценариев страницы
Одноразовость продления	Использованный маркер продления сразу становится недействительным
Повторное использование маркера продления	Завершается соответствующая семья сессии; другие независимые сессии работника не считаются продолжением этой семьи
Отзыв сеансов	Сервер проверяет актуальность сессии при последующих обращениях; отзыв не ожидает окончания срока уже выданного маркера доступа
Защита от подбора	Блокировка учётной записи после серии неудачных попыток с нарастающим сроком и ограничение частоты попыток с одного адреса

Защита от подбора устроена так. Пять неудачных попыток за пять минут закрывают вход в учётную запись, и каждая следующая серия из пяти попыток закрывает его дольше предыдущей: сначала на минуту, затем на пять, пятнадцать, тридцать минут и на час. Час - предел, выше срок не поднимается. Отсчёт возвращается к началу после успешного входа и после суток без единой неудачной попытки; администратор может снять

блокировку досрочно в карточке работника, не дожидаясь конца срока. Работник на странице входа видит, сколько осталось ждать.

Отдельно от учётной записи считаются попытки с одного сетевого адреса: те же пять неудач закрывают вход с этого адреса на минуту, и этот срок не растёт. Нарастающий срок к адресу не применяется намеренно: за одним внешним адресом работает целый отдел, и ошибки одного работника не должны запирать остальных.

Несуществующий логин закрывается на те же сроки и тем же сообщением, что и настоящий. Это сделано намеренно: если бы выдуманное имя всегда запиралось на минуту, а настоящее уходило на пять и пятнадцать, по длительности блокировки можно было бы выяснять, какие учётные записи в системе есть.

Сбой самой системы в счёт неудачных попыток не идёт. Если вход не удался не из-за пароля, а из-за того, что база данных недоступна, исчерпан пул соединений или запрос не уложился в срок, система отвечает отдельным сообщением - **«Вход временно недоступен из-за ошибки на сервере. Повторите попытку позже.»** - и лестницу блокировки не двигает. Иначе после аварии работники оказались бы заперты за то, чего не делали. Причина такой неудачи записывается и в журнал событий, и в системный журнал: журнал событий живёт в той же базе и при полной аварии не сохранится, а системный её переживает.

При входе создаётся отдельная семья сессии. Ротация маркера продления сохраняет связь с этой семьёй. Повторное предъявление использованного маркера завершает соответствующую семью; независимые входы работника на других устройствах учитываются отдельно. Выход из текущего сеанса отзывает его семью. Завершение всех сеансов и административные действия применяют предусмотренный для них объём отзыва.

Хранятся два маркера по-разному, и различие здесь существенно. Маркер доступа система держит в памяти открытой вкладки, без постоянной

записи в хранилище браузера: после закрытия вкладки он там не остаётся. Это сокращает срок его хранения, но само по себе не защищает от выполнения вредоносного сценария в открытой странице; для этого используются отдельные меры из подраздела 13.5. Маркер продления браузер получает файлом cookie, закрытым от сценариев страницы: страница этот файл не читает, а браузер сам прикладывает его к обращениям к системе, поэтому после обновления страницы работа продолжается без повторного ввода пароля. Файл передаётся только по защищённому соединению, при переходах с чужих сайтов не отправляется, живёт 7 суток и прикладывается лишь к обращениям к программному интерфейсу системы. Выход из системы его удаляет.

При чтении загруженных файлов браузер может предъявлять cookie сеанса. Сервер проверяет актуальную семью сессии и состояние учётной записи; само наличие cookie не является достаточным разрешением. Чтение файла не продлевает сессию. Если указан недействительный заголовок авторизации, он не заменяется другой личностью из cookie.

Других файлов cookie система не устанавливает. Счётчиков посещаемости, рекламных и аналитических меток в ней нет: наблюдение за работой ведётся по журналам на сервере, где действие и без того связано с учётной записью. Все файлы, которые система ставит, обслуживают вход и сеанс работы, поэтому отдельного согласия на них не требуется; согласия на обработку персональных данных описаны в подразделе 13.8.

Требования к паролю задаются в разделе «Настройки», вкладка «Безопасность», и действуют на любую установку пароля: при заведении учётной записи, при смене работником, при смене администратором и при обновлении паролей всем работникам. Настраиваются минимальная длина - от 6 до 128 символов, по умолчанию 8 - и обязательное присутствие буквы, заглавной буквы, строчной буквы, цифры и специального знака по отдельности; из поставки включены требование буквы и требование цифры.

Проверка выполняется на сервере, поэтому обойти её обращением к системе мимо интерфейса нельзя.

Срок действия пароля настраивается там же и в поставке выключен: включать его должен человек осознанно. При включённом сроке система ежесуточно в 04:00 отбирает работников, чей пароль старше заданного числа суток, и каждому из них поднимает требование сменить пароль. Сам пароль при этом не меняется и никуда не отправляется: работник входит своим прежним паролем, а дальше формы смены пароля система его не пускает. Срок задаётся в пределах от 30 до 120 суток, по умолчанию 90. Верхняя граница взята из приказа ФСТЭК России N 21, который для информационных систем персональных данных требует смены пароля не реже чем раз в 120 суток. За заданное число суток до истечения - от 0 до 30, по умолчанию 7, ноль означает не предупреждать - работник получает письмо и уведомление о том, что срок подходит; сменив пароль сам, он начинает отсчёт заново, и требовать смены системе будет уже нечего.

Так пароль работника при обновлении по сроку нигде не появляется в открытом виде: он остаётся известен только своему владельцу и хранится в системе единственным способом - вычислением Argon2id. Почтовая рассылка нужна здесь лишь для предупреждения о скором истечении; сама проверка сроков без неё работает, а работник, у которого адрес не указан, узнаёт об истечении на входе. Заблокированных работников и учётные записи, перенесённые в архив, проверка не касается вовсе: входить им и без того некуда.

Пароль, придуманный самой системой, появляется при трёх действиях администратора: заведении учётной записи, обновлении паролей всем работникам и смене пароля из карточки работника. Такой пароль не короче 12 символов, взят из криптографического источника случайности и заведомо удовлетворяет действующим требованиям. Визуально неоднозначные знаки из набора исключены - такой пароль переписывают из письма руками, и

путаница единицы со строчной латинской L стоит обращения в бюро пропусков.

При заведении учётной записи поле пароля можно оставить пустым, и тогда пароль придумывает система, а тот, кто заводит запись, его не видит. Пустое поле допустимо только при указанном адресе почты и настроенной рассылке: пароль, который негде прочитать, запирает работника снаружи, поэтому в остальных случаях система отказывает и просит задать пароль вручную. Заданный вручную пароль остаётся способом завести учётную запись человеку без адреса почты. Требование задать свой пароль при первом входе поднимается в обоих случаях: и придуманный системой, и заданный администратором пароль прошёл через чужие руки.

Работнику он уходит письмом открытым текстом. Это осознанный размен: другого канала связи с работником у системы нет, и доставить придуманный за него пароль иначе нечем. Оба действия исключительные - раздача паролей при вводе системы в эксплуатацию, подозрение на утечку, потерянный работником пароль, - и повседневное обновление по сроку на них не опирается. Риск дополнительно ограничен сроком жизни такого пароля: при включённом требовании сменить пароль при первом входе - включено по умолчанию - присланный пароль годится ровно на один вход. Пока работник не задаст свой, система отвечает отказом на любое обращение, кроме тех, без которых не открылись бы сама форма смены пароля и выход из системы. Заданный работником пароль отменяет присланный, и лежащее в почтовом ящике письмо перестаёт что-либо открывать.

Требование сменить пароль при первом входе или по истечении срока учитывается при проверке текущего состояния учётной записи. Срок действия ранее выданного маркера не отменяет это требование. Доступными остаются предусмотренные действия для выполнения требования и завершения сеанса.

При собственной смене пароля текущая сессия сохраняется, а остальные сессии учётной записи завершаются. Интерфейс обновляет состояние текущего входа и сообщает о необходимости повторного входа на других устройствах. Административный сброс завершает сессии целевой учётной записи. Изменение пароля и отзыв выполняются согласованно: ошибка операции не считается успешной сменой. События фиксируются в истории; сам пароль в журнал не записывается.

Вернуться к прежнему паролю система не даёт: десять последних паролей учётной записи запоминаются, и попытка задать любой из них отклоняется. Правило одинаково для всех путей смены - работник меняет пароль сам, администратор задаёт его из карточки, система обновляет пароли всем - и распространяется на пароль, придуманный самой системой: иначе работник, получив письмо, задал бы себе пароль из этого же письма. Первый пароль запоминается вместе с заведением учётной записи. Хранятся, как и действующий пароль, только вычисления Argon2id, поэтому сравнение с перечнем означает вычисление хеша заново на каждую запись - отсюда и глубина в десять, а не «все за всю историю»: проверка обязана укладываться в доли секунды, а не в секунды. Перечень наружу не отдаётся ни одним методом, в истории учётной записи и выгрузках не показывается, записи глубже десятой удаляются при очередной смене, а вместе с учётной записью исчезает целиком.

Свой пароль работник меняет в личном кабинете кнопкой «Сменить пароль», подтверждая текущий пароль. Для учётной записи типа «Охранник» собственной формы нет: пароль ведёт бюро пропусков. Подтверждение нужно потому, что перехваченный чужой сеанс без него давал бы смену пароля, то есть полный захват учётной записи. Отдельно администратор может сменить пароль одному работнику с отправкой письмом - это замена прежнего порядка, при котором пароль придумывали руками и диктовали по телефону, то есть он проходил через третьи уши.

Работников, у которых не указан адрес почты, обходят стороной только действия, высылающие придуманный пароль: сменить пароль и не доставить его - значит запереть человека снаружи. Их перечень система показывает администратору до обновления паролей всем работникам и называет в отчёте по каждому такому прогону. На требование сменить пароль по истечении срока отсутствие адреса не влияет.

Парольные операции используют общий ограниченный допуск до открытия транзакции. `ARGON2_HASH_CONCURRENCY` задаёт число вычислений, мест ожидания вдвое больше; ожидание длится не более двух секунд. При занятости возвращаются HTTP 503 и Retry-After: 2, а не ошибка пароля. Отмена ожидания учитывает контекст запроса; уже начатое вычисление удерживает свой слот до завершения. Поддерживается профиль Argon2id v19 с параметрами m=19456, t=2, p=1, солью 16 байт и результатом 32 байта, использовавшийся существующими Go- и Rust-генераторами. Иной или повреждённый сохранённый профиль отклоняется до дорогостоящего вычисления. Для неизвестного логина выполняется одно ограниченное вычисление текущего профиля; это не обещание идентичного времени всех ответов.

Состояние ограничителей частоты и входа в памяти ограничено отдельно от числа выполняемых операций. При исчерпании бюджета состояния новые записи не вытесняют ещё действующие счётчики или ступени блокировки ради допуска нового адреса. Отказ вместимости возвращает временную занятость с Retry-After; он отличается от HTTP 429 за превышение частоты и от неверного пароля. Ограничение памяти вспомогательных массивов не является пределом всей памяти процесса.

13.2. Разграничение доступа

Модель прав описана в подразделе 4.2. С точки зрения защиты информации существенны три её свойства.

Проверка выполняется на сервере при каждом обращении. Скрытие кнопки или пункта меню в интерфейсе рассматривается как удобство, а не как мера защиты: работник, обратившийся к системе в обход интерфейса, получит отказ на общих основаниях.

При проверке именованного права отсутствие разрешения означает отказ. Доступ к конкретному объекту дополнительно определяется его политикой: авторством, назначением, видимостью и текущим состоянием. Например, собственные поданные документы заявителя доступны по предусмотренному исключению; назначение согласующим само по себе не отменяет запрет согласования.

Каждый отказ фиксируется в журнале с указанием работника, запрошенного действия и времени.

13.3. Вход от имени другого работника

Режим позволяет администратору проверить доступность раздела или действия в контексте выбранного работника, не узнавая его пароль. В журнале сохраняется связь с администратором, выполняющим действия.

Кому доступен. Режим закрыт правом «Вход от имени пользователя». Одного права мало: сервер дополнительно сверяет полномочия сторон и отказывает, если у выбранного работника есть право, которого нет у самого администратора. От имени супер-администратора не входит никто, от имени администратора - только супер-администратор. Без такой проверки режим сам стал бы способом повысить себе полномочия: достаточно выбрать более полномочного человека и действовать его правами. Не открывается режим и для учётных записей, которые не пускают собственного владельца, - отключённых, заблокированных и тех, кому назначена обязательная смена пароля.

Что в режиме запрещено. Граница проведена по судьбе учётной записи: смотреть чужими глазами можно, распоряжаться учётной записью - нельзя. Чтение ограничено правами, видимостью объектов и текущим

состоянием выбранной учётной записи. Режим не открывает ей дополнительные данные. Изменяющие обращения сверяются с закрытым перечнем, и попытка выполнить закрытое действие получает отказ с предложением вернуться в свою учётную запись.

Таблица 13.2 — Действия, недоступные при работе от чужого имени

Что закрыто	**Почему**
Смена пароля - своего, чужого, рассылкой всем работникам	Свой пароль в этом режиме - пароль работника, и смена отняла бы у владельца доступ к собственной учётной записи
Изменение общесистемных настроек	Под ними срок действия паролей и прочие общие параметры; менять их из чужой учётной записи незачем
Перенос учётных записей в архив и восстановление из архива	Распоряжение судьбой учётной записи, в том числе чужой
Смена типа учётной записи, роли, признака администратора, групп прав	Через них администратор закрепил бы за собой полномочия чужими руками
Правка прав, групп прав и ролей	То же самое, но в обход карточки работника
Блокировка, разблокировка, снятие блокировки входа	Распоряжение доступом, пусть и в пользу владельца
Вход от имени третьего работника	Иначе проверка полномочий обходится в два шага
Подтверждение и отзыв согласия на обработку персональных данных	Согласие человек даёт за себя; подтверждение чужими руками согласием не является, а отзыв чужими руками отнимает у работника доступ

Срок доступа. Маркер, выданный от чужого имени, действует 30 минут и не продлевается: режим нужен на время разбора одного обращения, а забытая вкладка не должна оставаться чужой учётной записью до конца рабочего дня. По истечении срока сеанс сам возвращается в учётную запись администратора. Пока режим открыт, внизу экрана постоянно висит полоса с именем работника, остатком времени и кнопкой возврата: администратор, забывший, от чьего имени действует, - худший исход из возможных, и полоса не перекрывается ничем.

Что остаётся в журнале. Открытие и закрытие режима записываются отдельными событиями в историю той учётной записи, от чьего имени работали: кто открыл сеанс, когда и до какого времени он был действителен.

Пара таких записей задаёт окно, внутри которого действия учётной записи принадлежат не её владельцу. Каждая запись, сделанная внутри окна, дополнительно несёт отметку об инициаторе режима, поэтому отличить действия администратора от действий самого работника можно и не сверяясь с границами окна. Работник в журнале администратором не подменяется намеренно: история сущности отвечает на вопрос, под какой учётной записью выполнено действие, а на вопрос, кто его затеял, отвечает отметка.

13.4. Защита передаваемых данных

Соединение защищается протоколами TLS 1.2 и 1.3, устаревшие версии и слабые алгоритмы отключены. Обращения по незащищённому протоколу перенаправляются на защищённый.

Дополнительно передаются заголовки, ограничивающие поведение браузера: обязательное использование защищённого соединения, запрет встраивания страниц системы в чужие сайты, запрет угадывания типа содержимого, ограничение источников загружаемых ресурсов, запрет доступа к камере, микрофону и определению местоположения.

13.5. Защита от типовых атак

Таблица 13.3 — Меры против типовых атак

Угроза	Мера защиты
Внедрение команд в запрос к базе данных	Все запросы к базе параметризованы. В конструкторе отчётов имена полей подставляются только из фиксированного перечня, заданного в коде, а не из введённого пользователем текста
Выполнение чужого сценария в браузере	Форматированный текст очищается перед выводом по перечню разрешённых элементов, встроенные сценарии и обработчики событий удаляются
Обращение к чужим данным по идентификатору	Принадлежность проверяется на сервере. Перечень заявок обычному работнику возвращает только его собственные
Обращение к загруженным изображениям без входа в систему	Раздача файлов проверяет тот же cookie сеанса, что и остальные обращения: знание адреса файла доступа не даёт
Действия в обход интерфейса	Права проверяются на сервере при каждом обращении

Продолжение таблицы 13.3

Угроза	Мера защиты
Загрузка вредоносного файла	Тип определяется по содержимому файла, а не по расширению, поэтому переименование не помогает. Размер ограничен, имя файла на диске заменяется на служебное
Подбор пароля	Ограничение частоты попыток и блокировка учётной записи
Избыточная нагрузка запросами	Ограничение числа запросов на работника и отдельное, более строгое, ограничение попыток входа
Обход чёрного списка подменой букв	Записи и запросы приводятся к единому виду перед сравнением, подмена русских букв латинскими не срабатывает

Тяжёлые команды, импорт, загрузки и подготовка выгрузок делят ограниченный бюджет процесса: одновременно от одной до двух операций в зависимости от GOMAXPROCS, очередь вдвое больше, ожидание до двух секунд. Переполнение возвращает HTTP 503 с Retry-After: 2. Допуск не заменяет авторизацию и берётся до транзакций и согласующих блокировок. Для команд и импорта действует контекст до 120 секунд; подготовка выгрузки и работа с БД ограничиваются отдельно от последующей передачи файла. Малые запросы входа, продления сеанса и выхода имеют предел тела 64 КиБ. Общие пределы прокси требуют настройки по измеренной нагрузке: они не гарантируют защиту канала или виртуальной машины от любой атаки.

Документы OOXML проверяются как пакет до сохранения: проверяется структура, допустимые части, контрольные суммы и текстовые данные. Суммарно фактически прочитанные распакованные данные ограничены 64 МиБ. Ограничения сжатого файла и разрешённых форматов определяются маршрутом и не расширяются этой проверкой. Она не заменяет антивирус или полную проверку схем Office.

До чтения тела API-запроса действует отдельный общий допуск: восемь запросов с телом на процесс, без очереди ожидания. Он не зависит от HTTP-метода и не опирается только на Content-Length: распространяется также на chunked и HTTP/2 с телом без объявленной длины. Запрос без тела не занимает этот слот; обычное параллельное чтение, SSE и скачивание без тела сохраняют отдельные бюджеты. Максимум тела на этом уровне — 50 МиБ, более строгие пределы конкретных маршрутов продолжают

действовать. Превышение размера возвращает HTTP 413, занятость — HTTP 503 с Retry-After: 2. Слот освобождается после прекращения чтения и очистки временных multipart-файлов, включая отказ, отмену и прерывание обработчика. Передача запросов через nginx выполняется без предварительной полной буферизации тела и по HTTP/1.1 к upstream; предел числа тяжёлых операций при этом остаётся отдельным.

13.6. Защита персональных данных при хранении

Сведения документов, удостоверяющих личность, хранятся в базе в зашифрованном виде. Применён алгоритм AES-256 в режиме, который обеспечивает одновременно скрытие содержимого и защиту от подмены.

Штатные методы моделей выполняют шифрование при записи и расшифровку при чтении. Это не защита от произвольного прямого вмешательства в базу; доступ к ней и ключам ограничивается отдельно.

Поиск по зашифрованным полям решён отдельно: рядом с зашифрованным значением хранится необратимая свёртка, вычисленная с секретным ключом. Поиск ведётся по ней, что позволяет находить запись, не расшифровывая всю таблицу и не раскрывая содержимое.

Тем же ключом шифруются файлы, приложенные к заявке. Поле, в которое их кладут, общее, и что именно окажется в приложенном документе, система заранее не знает, поэтому содержимое считается сведениями о людях. Хранить номер документа зашифрованным, а его снимок рядом открытым не имело бы смысла: резервная копия файлов уносила бы то, что защищено в базе. Файл записывается по частям, расшифровывается при выдаче на лету и целиком в память не читается. Признак того, что файл был обрезан, проверяется вместе с расшифровкой: без него укороченный файл открывался бы как целый.

Изображения при загрузке перекодируются и уменьшаются до предела, заданного параметром установки. Вместе с перекодированием пропадают

служебные сведения снимка - в том числе координаты места съёмки и модель устройства, которых в самом документе нет.

Файлы, которые система выкладывает в файловый архив - бланки и машиночитаемые описания заявок, - шифруются на двух получателей сразу. Первый получатель принимающая сторона: файл открывается её закрытым ключом, а на сервере бюро этого ключа нет вовсе, поэтому доступ к каталогу или к его копии документов не даёт. Второй получатель сама система: без него она не прочитала бы собственный архив и не собрала бы выгрузку по кнопке в карточке заявки. Применён тот же формат и тот же порядок обращения с ключами, что и при шифровании резервных копий.

Шифрование архива требует пары ключей. Штатный сценарий подготовки установки создаёт их и задаёт `REQUIRE_ENCRYPTION=true`; отсутствие необходимых ключей блокирует запуск. Пустые исходные значения ключей в конфигурации не означают, что новая установка допускает незашифрованный архив. Такой режим возможен только при явно отключённом требовании на прежней установке. Заданный ключ принимающей стороны без ключа системы отклоняется при запуске - иначе служба записывала бы файлы, которые сама открыть не может. Файлы, записанные до включения, продолжают читаться: признак берётся из имени файла, а не из настройки.

Даже с шифрованием каталог архива защищается наравне с базой: доступ нужен прикладной службе и уполномоченному эксплуатационному персоналу для необходимых операций. Прямой сетевой доступ не заменяет выдачу через приложение и не применяет её ограничения согласий. Каталог не может находиться внутри публичной раздачи — это проверяется при запуске. Внешние общие ресурсы и прежние права каталогов требуют отдельной эксплуатационной проверки, см. руководство по развёртыванию и сопровождению, подраздел 9.7.

Заполненными полями карточки эти сведения выходят из системы бланком заявки, и этот путь разграничен (снимок документа, приложенный к

заявке файлом, живёт по своим правилам, см. подраздел 13.6 выше и подраздел 6.1). Инициатор заявки получает их без всякого права: паспорта и патенты участников он сам вносит в форму подачи, из своей же заявки они и уходят, а прочерки в его бланке читались бы как неисправность. Круг здесь намеренно узкий - именно подавший заявку, а не всякий, кому она доступна: согласующие, принимающие и получатели пересылки её только читают, и для них действует общее правило. Работник, не подававший эту заявку и не имеющий права на выгрузку сведений документов, получает бланк, в котором на месте серии и номера паспорта, номера патента и иного разрешения стоит длинное тире. Прочерк ставится и там, где поле не заполнено: пустая ячейка рядом с прочерками сама сообщала бы, что документа у человека нет, а это то же сведение о нём. Остальное содержание бланка не меняется - фамилия, должность, гражданство, сроки и места остаются на месте, потому что по этому бланку работает проходная.

Работник, которому право выдано, выбирает наполнение при скачивании переключателем: бланк со сведениями документов или без них. Положение по умолчанию закрытое - вынос сведений из системы должен быть решением, а не тем, что произошло само. Текущая политика документных полей применяется при формировании и просмотре актуального бланка. Сохранённые исторические оригиналы не редактируются на лету и имеют самостоятельные, более строгие ограничения выдачи, см. подраздел 6.1. Проверка выполняется на сервере, поэтому подстановка признака в адрес ссылки прав не добавляет.

Соответствие ключа данным система проверяет сама при каждом запуске: в служебной таблице хранится контрольное значение, зашифрованное действующим ключом, и оно сверяется до приёма обращений. Если ключ подменён, создан заново вместо утраченного или убран с зашифрованной базы, прикладной сервер не поднимается и называет причину в журнале, а данные остаются нетронутыми. Проверка закрывает случай, при котором система работала бы внешне исправно, показывая

вместо сведений документов нечитаемый набор символов: сохранение такой записи зашифровало бы её повторно, после чего не помог бы и прежний ключ. Плановая смена ключа выполняется отдельной командой, которая переводит значения со старого ключа на новый одной операцией и обновляет контрольное значение; порядок описан в руководстве по развёртыванию и сопровождению.

> **ОПАСНО.** Ключ шифрования является единственным способом прочитать эти сведения. При его утрате данные не восстанавливаются ни из резервной копии базы, ни средствами разработчика: копия содержит те же зашифрованные значения. Порядок хранения ключа описан в руководстве по развёртыванию и сопровождению.

При обработке изображений сервер проверяет исходные размеры до полного декодирования: не более 25 миллионов пикселей (ширина × высота), независимо от размера сжатого файла. Изображение 6000 × 4000 имеет 24 миллиона пикселей, 6000 × 5000 — 30 миллионов и превышает лимит. Параметры размера файла и уменьшения длинной стороны действуют отдельно.

13.7. Учёт обращений к персональным данным

Ведётся отдельный журнал обращений к сведениям о людях. Записываются работник, характер действия (просмотр, создание, изменение, удаление), затронутый раздел, сетевой адрес, время и результат.

Журнал доступен администратору в разделе администрирования системы, с фильтрами по работнику, действию и периоду. Открывается он по отдельному праву, то есть доступ к самому журналу тоже разграничен.

Записи хранятся 36 месяцев и не удаляются вместе с обычным журналом запросов. Запись выполняется в фоне и не замедляет работу пользователя, при этом сведения о запросе снимаются до передачи в фоновую задачу, что исключает их искажение.

Наравне с обращениями к карточкам людей учитывается и вынос сведений файлами. В журнал попадают выгрузка заполненного бланка,

выгрузка файлового архива за период, скачивание отдельного файла архива и архива одной заявки, просмотр перечня выложенных файлов, оценка объёма выгрузки, перечень и скачивание файлов, приложенных к заявке, выгрузка перечня заявок за период из центра заявок, а также снятие журнала обращений файлом. Это самый массовый вынос сведений из системы: один архив за месяц уносит бланки сотен заявок, и учитывать его поштучно важнее, чем открытие одной карточки. Выгрузка за период идёт по одноразовому билету и заголовка с маркером доступа не несёт, поэтому работник в записи определяется по билету, а не по запросу.

13.8. Согласия на обработку персональных данных

Согласие пользователя системы за себя учитывается отдельно от подтверждения при подаче заявки. Для согласия пользователя фиксируются его вид, сетевой адрес, сведения о браузере и время подтверждения. Отзыв этого согласия также фиксируется временем. При подаче заявки заявитель подтверждает уведомление указанных лиц и правомерность передачи сведений; это не заменяет согласие пользователя своей учётной записи.

Вместе с согласием сохраняются редакция текста и его контрольная сумма. Редакция отвечает на вопрос, какое требование выполнял работник, контрольная сумма - какой именно текст он видел: администратор может поправить формулировку, не повышая редакцию, и без контрольной суммы подтвердить содержание принятого текста было бы нечем. Обе величины ставит сервер по текущим настройкам, из запроса они не принимаются.

Документ об обработке персональных данных публикуется администратором в системе и доступен по ссылке из формы подачи заявки. Если задан текст согласия, на этой странице показывается он - тот же текст, который работник подтверждает при входе; загруженный файл остаётся доступным для скачивания. Когда текст не задан, страница показывает сам файл.

Обязательное согласие при входе. Администратор может потребовать согласие от всех работников: в разделе «Обработка данных» включается признак и задаётся текст согласия. Пока признак выключен или текст не заполнен, требование не действует и работа идёт обычным порядком.

Текст можно набрать в редакторе или получить из загруженного документа: при загрузке файла его содержимое переносится в редактор сразу. Разбор восстанавливает абзацы, нумерованные пункты, маркированные списки и заголовки; поддерживаются форматы PDF, DOCX и XLSX, для остальных текст вводится вручную. Таблицы разбор не воспроизводит, а собственная нумерация текстового процессора в содержимое файла не входит, поэтому результат рассчитан на вычитку администратором перед сохранением.

Работник, не давший согласия, видит окно с текстом. До согласия ему доступны только само согласие, чтение опубликованного документа и выход из системы; остальные действия система отклоняет. Супер-администратор проходит всегда - иначе ошибку в настройке согласия было бы невозможно исправить через интерфейс.

Если включены соответствующие настройки, при первом входе могут потребоваться согласие с текстом и смена выданного пароля. Для учётных записей, которым доступны оба действия, порядок между ними задан - сначала согласие, затем пароль, - и пока открыто окно согласия, требование сменить пароль его не перебивает. Порядок именно задан, а не сложился: два независимых требования, каждое из которых закрывает всё постороннее, иначе закрыли бы друг другу единственный выход, и работник не попал бы в систему вовсе.

У текста есть редакция. При сохранении изменённого текста система спрашивает администратора, запросить ли согласие заново у всех: изменённый текст - это новая редакция, и подтверждать её обычно надо заново, но правка опечатки того не стоит. По утвердительному ответу редакция повышается тем же действием, что и сохранение текста, -

раздельные шаги оставляли бы промежуток, в котором работникам показывают новый текст, а достаточным считается согласие, данное прежнему. Отказ сохраняет текст, не трогая редакцию. Повысить редакцию без правки текста можно отдельной командой в том же разделе. Согласие работника считается действующим, пока его редакция не ниже требуемой.

Ход сбора виден в том же разделе: доля подтвердивших текущую редакцию и поимённый список тех, кто ещё нет, с выгрузкой в электронную таблицу. Счёт ведётся по тем работникам, кого требование реально касается: без учётной записи супер-администратора, без архивных и заблокированных. Пока требование выключено, сбор не идёт и сводка сообщает об этом, а не показывает нулевую долю.

Пока согласия нет, персональные данные работника не видят другие. Скрываются и фамилия с именем и отчеством, и рабочие контакты - почта и телефон. Вместо ФИО система показывает остальным логин учётной записи: в списках работников и заявок, в истории, вопросах, отметках прочтения, на экране поста, в справочниках, журналах, отчётах и аналитике. Логин выбран намеренно: подпись вида «данные скрыты» сделала бы несколько строк неразличимыми, и согласующего в списке было бы не выбрать. Сквозной поиск, пока данные скрыты, по почте и телефону не ищет вовсе, иначе подсказка подтверждала бы, чей это адрес.

Скрытие касается только показа. Сами данные хранятся как были, и правка карточки работника их не затирает: поля, которых нет в запросе, система не трогает.

Скрытие снимается при наличии выданного и не отозванного согласия: одного исторического факта согласия недостаточно. Для отображения имени не требуется подтверждать именно текущую редакцию — повышение редакции само по себе не обезличивает всех работников. Маскирование действует при включённом требовании согласия и непустом тексте; правила выдачи исторических оригиналов отдельно учитывают неурегулированные отзывы, даже если это требование выключено, см. подраздел 6.1.

Маска имени принимающего и отсутствие согласия — разные основания. Заданную подпись принимающего обычные пользователи видят вместо его ФИО; действующие незаблокированные администраторы и суперадминистраторы могут работать с настоящим именем. Маскирование из-за отсутствия согласия имеет приоритет и не снимается административной ролью. Поиск, списки, история и выгрузки должны применять одну и ту же политику отображения.

Отзыв согласия. Работник отзывает своё согласие сам - в личном кабинете, отметкой согласия в верхней части страницы: она же показывает дату, когда согласие было дано. Если он обратился в бюро пропусков, отозвать согласие за него может администратор из карточки работника. В обоих случаях доступ закрывается сразу: система снова показывает окно согласия, и до нового подтверждения работать в ней нельзя - об этом предупреждает вопрос, который задаётся перед отзывом.

Уведомление субъекта, чьи данные вносит заявитель. Согласие пользователя за себя и уведомление человека, чьи данные вводятся в заявку, учитываются отдельно. В форме сотрудника заявитель подтверждает «Работник уведомлён об обработке персональных данных». Такое же подтверждение есть при создании записи в разделе «Сотрудники». Система сохраняет дату и учётную запись подтвердившего; значения ставит сервер, из запроса принимается факт подтверждения. Историческое имя поля в программном интерфейсе — `pd_consent`; подпись интерфейса описывает уведомление.

В форме новой записи реестра отметка обязательна. При подаче заявки показ и обязательность поля определяет настройка вида вложения, см. руководство администратора, подраздел 12.4: обязательное поле проверяется сервером у каждой соответствующей строки. Снятие отметки при повторном сохранении не удаляет уже поставленную дату уведомления. Возражение против обработки учитывается отдельно и не снимается обычной правкой карточки.

При выборе человека из реестра используется сохранённая отметка уведомления. При загрузке списка из бланка подтверждение задаётся для загружаемого списка: отдельной колонки под него в файле нет.

Выдача и отзыв согласия пользователя за себя попадают в историю его учётной записи. В записи о выдаче сохраняется редакция текста; в записи об отзыве видно, отозвал пользователь согласие сам или это сделал администратор по его обращению. В разделе работников состояние этого согласия видно без открытия истории: у не подтвердившего вместо фамилии стоит пометка, а в карточке — дата согласия либо отметка, что его нет.

13.9. Журналы и прослеживаемость

Таблица 13.4 — Журналы системы

Журнал	Что фиксирует	Кому доступен
Журнал запросов	Все обращения к системе: работник, действие, результат, длительность	Администратору и работникам с правом просмотра
Журнал обращений к персональным данным	Обращения к сведениям о людях	По отдельному праву
Журнал изменений	Кто, когда и что изменил в сущностях системы	Администратору
Журнал отказов в доступе	Попытки выполнить действие без прав	Администратору
Журнал входов	Входы, выходы, неудачные попытки, блокировки и их снятие администратором	Администратору

Совокупность журналов позволяет восстановить картину по любому вопросу вида «кто это сделал и когда».

Журнал изменений хранит и удаления: запись справочника сотрудников или автомобилей удаляется из базы безвозвратно, поэтому вместе с отметкой об удалении сохраняются имя удалившего, время и снимок удалённого - фамилия работника либо номер и марка машины. Без снимка запись журнала указывала бы на номер строки, которой уже нет, и ответить на вопрос «кого именно убрали» было бы нечем. Администратор читает эти события в разделах «Сотрудники» и «Автомобили» кнопкой «Журнал», см. руководство администратора, подраздел 10.8.

> **ПРИМЕЧАНИЕ.** Неудача входа по вине системы записывается в журнал входов без привязки к учётной записи - в этот момент система ещё не знает, кто именно пытался войти. В личной истории входов работника такие записи не показываются; их смотрят по имени учётной записи при разборе происшествия.

Адрес запроса записывается в журнал с затёртыми значениями параметров. Перечень безопасных параметров закрытый: значение сохраняется только у тех, которыми задают выборку, - номер и размер страницы, границы периода, метод и коды ответа, порог длительности, шаг ряда, порядок сортировки, признак архива, - а у всех остальных вместо значения остаётся отметка `***`. Имена параметров сохраняются полностью, поэтому по журналу видно, что работник искал по имени, но не видно, кого именно он искал.

Такой порядок выбран потому, что сроки жизни у передаваемого значения и у журнала несопоставимы: одноразовый билет действует меньше минуты и гасится при первом предъявлении, а журнал хранится месяцами, читается через интерфейс и выгружается в электронную таблицу. Перечень запрещённых закрывал только заранее известное - билет, маркер доступа, ключ выгрузки; для файлового архива это особенно важно, потому что билет открывает выгрузку бланков с паспортными сведениями. Всё остальное, включая строку поиска с фамилией или номером заявки, попадало в журнал открытым. Та же маска применяется и при выгрузке журнала файлом, поэтому записи, сделанные до перехода на закрытый перечень, наружу открытыми не уходят.

Снятие журнала файлом само записывается в журнал изменений: кто, когда, каким отбором и сколько строк унёс. Строка поиска в этот след не переносится - сохраняется только признак, что поиск был: иначе то, что затёрто в журнале, осело бы во втором хранилище.

Прикладной сервер и прокси используют идентификатор запроса для сопоставления записей. Итоговые HTTP-коды согласованы с обработкой ошибки; внутренние причины не выдаются клиенту как текст исключения,

SQL или содержимое запроса. Диагностические записи сохраняют безопасные категории и идентификаторы без автоматического копирования тела, заголовков авторизации и секретных значений. При ответе с ошибкой до начала передачи используется обычный обработчик; уже переданные байты потока нельзя заменить новым JSON-ответом. Ответы API не предназначены для общего кэша прокси или браузера.

13.10. Автоматический контроль защищённости

Поиск уязвимостей встроен в конвейер сборки и выполняется при каждом изменении программы, а также еженедельно по расписанию, когда сама программа не менялась. Последнее важно: сведения об уязвимости часто появляются уже после выпуска версии.

Таблица 13.5 — Средства автоматического поиска уязвимостей

Средство	**Что проверяет**	**Поведение при обнаружении**
govulncheck	Библиотеки серверной части на уязвимости из базы уязвимостей Go. Учитывает, вызывается ли уязвимый код фактически, что отсеивает ложные срабатывания	Сборка прерывается
npm audit	Библиотеки интерфейса, участвующие в сборке	Сборка прерывается при уровне «высокий» и выше
Trivy	Собранный образ контейнера целиком: системные пакеты операционной системы и библиотеки внутри образа	Сборка прерывается при уровне «критический» и «высокий»
gitleaks	Все коммиты хранилища исходного кода на присутствие паролей, ключей и маркеров доступа	Сборка прерывается при любой находке

Сканирование проверяет известные на момент запуска сведения. Для образов конвейер блокирует публикацию при найденных исправимых уязвимостях высокого или критического уровня; успешный результат не является доказательством отсутствия всех уязвимостей.

Проверка на присутствие секретов отличается от прочих тем, что смотрит не на текущее состояние программы, а на всю историю изменений:

пароль или ключ, удалённый из файлов позднее, остаётся в истории хранилища и доступен всякому, кто её получит. Разобранные срабатывания перечислены поимённо, каждое с пояснением, что это за значение; общего исключения по признаку «файл проверочный» не делается - ключ, положенный в проверочный код, остаётся ключом. Проверка, не увидевшая ни одного изменения, считается несостоявшейся и прерывает сборку так же, как находка: иначе этап сообщал бы об успехе, ничего не проверив.

Обновления библиотек предлагаются автоматически, сгруппированные по назначению, и проходят полный набор тестов до применения. Благодаря этому зависимости не устаревают незаметно.

Дополнительно проведён аудит разграничения доступа по методике проверки функциональной авторизации: последовательно проверялось, что каждое действие недоступно работнику без соответствующего права. Для исправленных сценариев добавлены регрессионные проверки разграничения. Они закрепляют проверенные условия, но не доказывают отсутствие ошибок во всём приложении; новые сценарии и изменения ролей требуют отдельной проверки.

14. Тестирование и обеспечение качества

14.1. Уровни тестирования

Качество обеспечивается тремя уровнями автоматических тестов. Каждый уровень ловит свой класс ошибок, и ни один не заменяет остальные.

Таблица 14.1 — Состав автоматических тестов

Уровень	Инструмент	Объём	Что покрывает
Бэкенд-тесты, модульные и интеграционные	Штатное средство тестирования Go	3026 тестов в 647 файлах	Обработку заявок, разграничение доступа, работу с данными, выгрузки, шифрование
Фронтенд-тесты	Vitest	6792 теста в 795 файлах	Поведение экранов и элементов, обработку данных на стороне браузера, хранилища состояния

Продолжение таблицы 14.1

Уровень	**Инструмент**	**Объём**	**Что покрывает**
E2E-сценарии, сквозные	Playwright	201 тест в 51 файлах	Работу системы целиком в браузере от входа до результата, а также прямые обращения к программному интерфейсу
Всего		10019	

Существенная особенность: бóльшая часть бэкенд-тестов выполняется **на настоящей базе данных**, которая разворачивается специально для прогона, а не на её упрощённой замене. Это медленнее, но обнаруживает ошибки в запросах, ограничениях целостности и правах, которые упрощённая замена пропустила бы в принципе. Точное число таких файлов приведено в разделе 15.

E2E-сценарии запускаются в настоящем браузере и повторяют действия работника: заполнение формы заявки, приём в работу, отметку въезда на посту, открытие разделов администрирования.

Отдельно поддерживаются тесты, закрепляющие разграничение доступа: они пытаются выполнить действие без права и требуют получить отказ. Такие тесты не дают случайно открыть доступ при доработках.

Количество в таблице — статический подсчёт объявлений тестов в исходниках, а не число выполненных случаев и не доказательство последнего успешного прогона. Параметризованные проверки могут создавать несколько случаев. Проверка чисел выполняется doc_facts.py по той же ревизии кода; результаты CI фиксируются отдельно.

14.2. Что дают тесты при сопровождении

Набор тестов нужен не сам по себе, а как страховка при внесении изменений. Практический эффект такой.

- Ошибка обнаруживается до выкладывания, а не пользователем на рабочем сервере.

- Доработка одной части системы, случайно сломавшая другую, будет остановлена: E2E-сценарии проходят по основным рабочим процессам целиком.
- Разграничение доступа защищено от случайного ослабления.
- Известные уязвимости в используемых библиотеках обнаруживаются автоматически, включая появившиеся уже после выпуска версии.

14.3. Автоматический конвейер сборки и проверки

Конвейер построен на GitHub Actions и запускается сам. Он состоит из трёх процессов с разными условиями запуска: это существенно, потому что не всё выполняется на каждое изменение.

Основной конвейер. Запускается на каждое изменение в основной ветке и на каждый запрос на слияние.

Таблица 14.2 — Этапы основного конвейера

Этап	Что выполняется
Определение изменений	Анализируется, какие части затронуты, чтобы не запускать лишнее
Проверка описания изменения	Описание проверяется на соответствие принятому формату
Статический анализ	Код серверной части проверяется на подозрительные конструкции
Бэкенд-тесты	Пять независимых групп с отдельными исполнителями и тестовыми базами: две группы обработчиков, две сервисов и остальные пакеты. Сохраняются все тесты, проверка гонок (`-race`), отключение повторного использования результата (`-count=1`) и предел 1000 секунд для пакета. Итоговая проверка Go Tests успешна только после всех групп
Проверка стиля интерфейса	Код интерфейса проверяется на соответствие правилам оформления, а файлы исходного кода - на предельный размер: новый файл обязан уложиться в предел, а файл, уже превышающий его, не может расти дальше
Проверка объёма загрузки	Интерфейс собирается, и объём файлов, которые браузер загружает при открытии страницы входа, сверяется с установленным пределом
Фронтенд-тесты	Прогон тестов интерфейса

Продолжение таблицы 14.2

Этап	**Что выполняется**
Сборка образов	Собираются шесть образов: прикладной сервер, веб-приложение, прокси стенда, прокси рабочего сервера, PostgreSQL и pgAdmin. Перед публикацией выполняется сканирование конечных образов, а для PostgreSQL — проверка запуска, перезапуска и сохранности данных. У прикладного сервера проверяется непривилегированный пользователь, у прокси стенда — наличие OpenSSL. Образы публикуются в GHCR с меткой SHA коммита
Выкладывание на стенд	Только при попадании изменения в основную ветку: стенд запускает четыре готовых образа одного SHA — сервер, веб-приложение, прокси и PostgreSQL; файлы конфигурации берутся из той же ревизии. pgAdmin остаётся отдельным инструментом профиля tools. До поставки проверяются доверенный ключ узла, успешный Security для точного SHA и актуальность вершины ветки; отдельное подключение только по deploy-ключу проверяет доступ к Docker без резервной парольной авторизации
Итоговый контроль	Отдельный этап, который завершается неудачей, если неудачей закончился любой предыдущий

Сквозные сценарии. Выполняются при запросе на слияние в основную ветку, если изменения затронули интерфейс или серверную часть. Прогон идёт в браузере на четырёх параллельных потоках, отчёт сохраняется при неудаче.

Сканирование уязвимостей и поиск секретов. Выполняется на изменения в основной и производственной ветках, а также еженедельно по расписанию. Расписание нужно потому, что сведения об уязвимости часто появляются уже после выпуска версии, когда сама программа не менялась. Тем же процессом вся история изменений проверяется на присутствие паролей, ключей и маркеров доступа. Состав средств приведён в подразделе 13.10.

Изменение, не прошедшее основной конвейер, к выпуску не допускается: итоговый контроль перекрывает выпуск, если хотя бы один этап завершился неудачей.

Обновления используемых библиотек предлагаются автоматически, сгруппированные по назначению, и проходят те же проверки, что и остальные изменения.

Проверка Security охватывает шесть конечных образов, в том числе оба варианта прокси и вспомогательный pgAdmin. Проверка перед публикацией и проверка Security дополняют друг друга. Автоматическая поставка на рабочий сервер дополнительно требует успешных CI и Security для точного SHA, текущей вершины производственной ветки и использования готовых образов этой ревизии. Настройка автоматических обновлений зависимостей не означает полного покрытия новых Docker-контекстов и закреплённых дополнительных пакетов: их сопровождение проверяется отдельно.

14.4. Проверочный стенд

Помимо рабочего сервера поддерживается отдельный стенд с той же системой. Изменения попадают на него автоматически после успешного прохождения проверок, что позволяет посмотреть их вживую до выкладывания на рабочий сервер.

Интерфейс стенда закрыт запросом имени и пароля, который выдаёт обратный прокси до входа в систему; программный интерфейс отвечает по маркеру доступа, как и на рабочем сервере. База у стенда отдельная, поэтому эксперименты на нём не затрагивают рабочие данные, а рабочие персональные данные на стенд не переносятся.

Порядок работы со стендом и порядок выкладывания на рабочий сервер описаны в руководстве по развёртыванию и сопровождению.

15. Масштаб системы

Сведения приводятся для оценки объёма разработки и трудоёмкости сопровождения.

Таблица 15.1 — Количественные показатели

Показатель	**Значение**
Объём исходного кода	601130 строк в 2671 файлах
Серверная часть	129567 строк без тестов: 255 служб, 84 обработчика, 92 модели данных
Экраны и элементы интерфейса	201243 строк: 40 экранов, 270 элементов
Методы программного интерфейса	549 в 41 группе
Таблицы базы данных	116

Продолжение таблицы 15.1

Показатель	Значение
Автоматические тесты	10019
Файлов бэкенд-тестов на настоящей базе	388

Объём исходного кода приведён по файлам серверной части и интерфейса вместе с тестами; сторонние библиотеки и сформированное из кода описание программного интерфейса в подсчёт не входят.

Число одновременно работающих пользователей определяется целевым оборудованием и нагрузочным профилем: частотой поиска, выгрузок, открытых таблиц и обновлений. Значения параметров пула и таймаутов сами по себе не доказывают производительность; её подтверждают отдельными нагрузочными испытаниями.

Приложение А. Категории прав доступа

Таблица А.1 — Категории прав

Категория	Содержание
Разделы навигации	Доступ к экранам системы
Элементы верхней панели	Действия, доступные из шапки
Центр заявок	Просмотр и обработка заявок, приём в работу, решения, дополнение поданной заявки
Карточки объектов	Просмотр карточек транспорта и людей, история, раздел сведений документов и их выгрузка в бланк
Реестры	Работа с реестрами людей и транспорта
Администрирование	Учётные записи, права, справочники, журналы, вход в систему от имени другого работника
Обзор и руководство	Доступ к разделам встроенной справки
Таблицы постов	Создаются автоматически для каждой таблицы: просмотр, отметки въезда и выезда, карточка, история, версии, выгрузка, отчёт по проходам, корзина, удаление

Категория администрирования не является одним правом: разделы внутри неё - справочники, учётные записи, настройки, журнал обращений к персональным данным, файловый архив, конструктор таблиц постов, мониторинг запросов - закрыты каждый своим ключом и назначаются по отдельности, см. подраздел 4.2.

Два действия доступны исключительно супер-администратору: включение режима технических работ и назначение прав администратора.

ЛИСТ РЕГИСТРАЦИИ ИЗМЕНЕНИЙ

В таблице фиксируются изменения документа. Версия повышается при выпуске новой редакции: вторая цифра при уточнениях и дополнениях, первая при переработке структуры или существенном изменении требований.

Таблица И.1 — Регистрация изменений

Версия	Дата	Содержание изменения	Внёс
1.0	28.07.2026	Первая редакция	
1.1	28.07.2026	Сверка с реализацией: уточнены количественные показатели, состав прав таблиц постов и поведение поиска	
1.2	28.07.2026	Описана защита вложения от повторного добавления одного человека или одной машины	
1.3	28.07.2026	Описан режим технических работ: объявляемые сроки и контакты, снятие режима по истечении срока	
1.4	30.07.2026	Обновлены количественные показатели; описан перенос длинного перечня в бланке вместе с шапкой столбцов	
1.5	30.07.2026	Обновлены количественные показатели: объём кода, число тестов и методов программного интерфейса	
1.6	30.07.2026	Описано обязательное согласие на обработку персональных данных при входе	
1.7	30.07.2026	Дополнен состав записи о согласии: редакция текста и его контрольная сумма; описан показ текста согласия на странице документа	
1.8	30.07.2026	Обновлены количественные показатели: объём кода, число тестов и сквозных сценариев	
1.9	30.07.2026	Описаны напоминания молчащим согласующим, признак нахождения работника в системе и перечень принимающих заявки	
1.10	30.07.2026	Описан просмотр хода сбора согласий администратором: доля подтвердивших и список остальных	
1.11	30.07.2026	Описана защита от подбора пароля с нарастающим сроком блокировки входа и её досрочное снятие администратором	
1.12	31.07.2026	Описан перенос текста согласия из загруженного документа и повторный запрос согласия при изменении текста; обновлены количественные показатели	
1.13	31.07.2026	Уточнено, что несуществующий логин запирается на те же сроки и тем же сообщением, что настоящий	
1.14	31.07.2026	Описано скрытие фамилии работника, пока он не дал согласия на обработку персональных данных	

Продолжение таблицы И.1

Версия	Дата	Содержание изменения	Внёс
1.15	31.07.2026	Описаны суточная уборка недействительных маркеров продления и прочитанных уведомлений и сроки хранения по группам; обновлены количественные показатели	
1.16	31.07.2026	Описан отзыв согласия на обработку персональных данных, запись выдачи и отзыва в историю учётной записи; уточнён состав сквозного поиска	
1.17	31.07.2026	Уточнено поведение поиска при опечатках; обновлены количественные показатели	
1.18	31.07.2026	Уточнено, что до согласия скрываются и рабочие контакты работника	
1.19	31.07.2026	Описан файловый архив бланков: раскладка по шаблонам, обновление и заморозка файлов, ограничение занятого места	
1.20	01.08.2026	Файловый архив описан целиком: слепок заявки, фоновое наполнение и ночная сверка, пороги места, раздел администрирования; отмечено, что сквозной поиск понимает опечатки	
1.21	01.08.2026	Лист регистрации изменений разделён по документам: у каждого своя редакция и свой перечень изменений	
1.22	03.08.2026	Файловый архив: раскладка каталогов по умолчанию, сверка содержимого по контрольной сумме и выгрузка сохранённых бланков из системы; описаны выдача выгрузки по одноразовому билету и учёт таких обращений в журнале персональных данных	
1.23	04.08.2026	Сверка раздела о файловом архиве с реализацией: раздел администрирования показывает месяц последней записи, отдельные файлы забирают из карточки заявки, уточнён срок жизни ссылки на выгрузку	
1.24	04.08.2026	Описано, что значения одноразовых билетов и маркеров доступа в журнал запросов не попадают	
1.25	04.08.2026	Описано состояние выгрузки, которое бланк получает в архиве и показывает в карточке заявки	
1.26	04.08.2026	Уточнён конвейер проверок: проверенные образы помещаются в хранилище, стенд забирает готовые образы оттуда	
1.27	05.08.2026	Уточнено описание раздела файлового архива: состав показателей обзора, лента записей реестра, представление действующих настроек	
1.28	05.08.2026	Описано дополнение уже поданной заявки: кто и в каких состояниях заявки может добавить людей, транспорт и ценности, отдельный круг согласования добавки у заявки в работе, видимость добавленного до принятия решения; описаны право на дополнение и хранение добавок и голосов по ним	

Продолжение таблицы И.1

Версия	Дата	Содержание изменения	Внёс
1.29	06.08.2026	Уточнено ограничение доступа к проверочному стенду: запрос имени и пароля закрывает интерфейс, программный интерфейс отвечает по маркеру доступа	
1.30	06.08.2026	Описано прикрепление файлов к заявке: хранение, шифрование и учёт обращений	
1.31	06.08.2026	Описаны уведомления: направления событий, настройка набора работником, сборка повторов в одну запись и подробности в отдельном окне; добавлено предупреждение об истечении срока действия пропуска	
1.32	07.08.2026	Уточнён срок хранения файлов, приложенных к заявке	
1.33	07.08.2026	Описана доставка уведомлений вне системы: сообщения на компьютер и телефон при закрытом сайте, условие установки приложения на устройствах Apple, связь с настройками работника	
1.34	07.08.2026	Описано шифрование файлового архива: два получателя, включение и совместимость	
1.35	07.08.2026	Описано, что приложенные к заявке файлы уезжают в архив вместе с её бланками	
1.36	08.08.2026	Описано извещение работника бюро о заявке, ждущей принятия в работу; уточнены доставка вне системы на компьютере и порядок установки на устройствах Apple	
1.37	08.08.2026	Уточнено, кому доступны общесистемные настройки и что супер-администратор дополняет любую заявку	
1.38	08.08.2026	Доступ к разделу «Настройки» описан как отдельное право администратора, а не действие супер-администратора	
1.39	08.08.2026	Описана выгрузка перечня заявок за период из центра заявок и её учёт в журнале обращений к персональным данным	
1.40	08.08.2026	Раздел обучения переписан под пять туров по кругу задач работника: выбор по правам, отдельный учёт прохождения, переход к нужному шагу; обновлены количественные показатели	
1.41	09.08.2026	Описан массовый ввод участников из бланка: выдача пустого бланка с отметкой вида пропуска, отклонение негодного файла целиком, проверка строк теми же правилами, что и при ручном вводе, исправление проблемных строк и выбор мест прохода на весь список; добавлено право на массовый ввод	
1.42	10.08.2026	Документ получил гриф конфиденциальности и лист ограничений на использование: цель передачи, запрет передачи третьим лицам и запрет воспроизведения описанного решения	

Продолжение таблицы И.1

Версия	Дата	Содержание изменения	Внёс
1.43	11.08.2026	В перечень периодических задач добавлен разбор очереди писем; обновлены количественные показатели	
1.44	11.08.2026	Описаны настраиваемые требования к паролю и срок его действия, плановая смена паролей с рассылкой новых паролей письмом и обязательной сменой при первом входе, смена собственного пароля работником и прекращение сеансов при смене; добавлены периодическая задача плановой смены и право на смену паролей всем работникам; обновлены количественные показатели	
1.45	11.08.2026	Описан вход администратора в систему от имени другого работника: право на режим, проверка полномочий сторон, перечень действий, закрытых в режиме, срок доступа и отметки в журнале; обновлены количественные показатели	
1.46	11.08.2026	Уточнено обновление паролей по истечении срока: система требует от работника задать новый пароль при входе, а не придумывает и не высылает его письмом; придуманный системой пароль отнесён к исключительным действиям администратора; обновлены количественные показатели	
1.47	12.08.2026	Описано заведение учётной записи с высылкой пароля письмом и запрет повторного использования паролей; задан порядок двух требований при первом входе - сначала согласие, затем свой пароль; обновлены количественные показатели	
1.48	11.08.2026	Описаны круг получателей заявки при подаче и пересылке, новое правило пересылки и список участников заявки с рабочими контактами; обновлены количественные показатели	
1.49	12.08.2026	Уточнена модель доступа к разделам администрирования: каждый раздел закрыт своим правом, вложенности между ними нет, порядок доступа администраторов не меняется; обновлены количественные показатели	
1.50	12.08.2026	Резервное копирование вынесено из перечня периодических задач прикладного сервера: его выполняет отдельный сценарий по расписанию операционной системы	
1.51	12.08.2026	Описано, что неудача входа по вине системы отвечает отдельно, не двигает лестницу блокировки и пишется в журнал без привязки к учётной записи	
1.52	12.08.2026	Описано, что повреждённая запись пароля не считается ошибкой работника и не запирает учётную запись, а сбой продления сеанса не прекращает работу; описано, кому видна пометка обязательного согласующего	

Продолжение таблицы И.1

Версия	Дата	Содержание изменения	Внёс
1.53	12.08.2026	Уточнено хранение письма с паролем: копия письма в системе не остаётся, текст стирается после отправки	
1.54	12.08.2026	Уточнён состав участников заявки: назначенные на неё работники перечислены согласующими, а обязательность голоса показана подписью, а не отдельной ролью	
1.55	12.08.2026	Раздел о разграничении доступа приведён к той же терминологии ролей; описано, что обязательность согласования при подаче определяется справочником организации, а не присланным значением	
1.56	13.08.2026	Описан признак обязательного согласования: источник - отметка в карточке организации или компании, а не выбор заявителя при подаче; работник вне состава организации или компании обязательным согласующим не становится, а расхождение присланного списка со справочником останавливает подачу заявки целиком. Показана разница с обычными получателями, которых лишний человек в списке не останавливает	
1.57	13.08.2026	Уточнена периодическая задача предупреждения об истечении пропуска: рассылка идёт ежесуточно в 09:00, заявитель предупреждается дважды - за три дня и накануне, а общим сроком заявки считается самая поздняя дата среди её действующих вложений	
1.58	14.08.2026	Версия языка прикладного сервера приведена к используемой - Go 1.26; счётчики тестов, методов и объёма кода пересчитаны по текущему состоянию репозитория	
1.59	14.08.2026	Лист условий использования сокращён и смягчён: оставлены принадлежность прав, запрет передачи третьим лицам и отсутствие лицензии; убраны срок действия ограничений, требования письменного согласия и подтверждения уничтожения копий	
1.60	14.08.2026	Свойства файла заполнены выходными данными документа: прежде в них стояли служебные значения средства сборки	
1.61	14.08.2026	Описан второй путь разбора пометки чёрного списка - исключение объекта из поданной заявки принимающим, - и предпросмотр последствий внесения в чёрный список	
1.62	15.08.2026	Уточнено, что пометка о сходстве действует ровно столько, сколько действует запрет: снятая запись чёрного списка гасит её сама	

Продолжение таблицы И.1

Версия	Дата	Содержание изменения	Внёс
1.63	17.08.2026	В технологической основе указано, что применённые библиотеки распространяются по разрешительным лицензиям, и дана отсылка к перечню сторонних компонентов в поставке	
1.64	17.08.2026	Описано согласие субъекта, чьи данные вносит заявитель: где ставится отметка, что сохраняется и почему у транспорта она выключена	
1.65	18.08.2026	Указано, что журнал изменений хранит удаления записей справочников сотрудников и автомобилей вместе со снимком удалённого	
1.66	19.08.2026	Описано хранение маркеров доступа и продления в браузере, состав устанавливаемых файлов cookie и отсутствие в системе счётчиков посещаемости; в мерах защиты названа проверка доступа к загруженным изображениям	
1.67	19.08.2026	В средства автоматического контроля добавлен поиск паролей и ключей во всей истории изменений	
1.68	19.08.2026	Уточнена выдача загруженных изображений: она требует входа в систему, а неугадываемость имени файла перестала быть единственной преградой	
1.69	19.08.2026	Отметка о согласии субъектов дописана в раздел о массовом вводе из бланка: подтверждается один раз на весь загруженный список	
1.70	20.08.2026	Переписан порядок затирания параметров в журнале обращений: значение сохраняется только у служебных параметров разбора, остальные затираются вместе с поисковыми строками; описан след выгрузки журнала в журнале изменений; мониторинг запросов дописан в перечень разделов, закрытых своим правом	
1.71	21.08.2026	Описано разграничение выгрузки сведений документов в бланк: пара прав, прочерк вместо значения у работника без права, выбор наполнения при скачивании и сужение круга допущенных к сохранённым копиям	
1.72	21.08.2026	Уточнено, что в окне скачивания бланков источник не выбирается: бланк собирается заново при каждом обращении, сохранённые копии забирают в разделе администрирования	
1.73	21.08.2026	Описана фоновая проверка доли серверных ошибок: при переходе порога работникам с правом на раздел мониторинга уходит уведомление; перечень системных событий дополнен записями справочника, которых в нём не хватало	
1.74	21.08.2026	Снятие журнала обращений файлом отнесено к учёту обращений к персональным данным: выгрузка попадает в журнал наравне с выгрузкой бланков, файлового архива и реестра заявок	

Продолжение таблицы И.1

Версия	Дата	Содержание изменения	Внёс
1.75	21.08.2026	Описано, что инициатор заявки получает сведения документов в бланке без права на их выгрузку: в форму подачи он вносит их сам	
1.76	25.08.2026	Описан переход из сквозного поиска к найденной записи, чтение выдачи по разделам и место архивных учётных записей в ней	
1.77	25.08.2026	Описаны главы обучающего тура, продолжение с прерванного места и примерная заявка для работника без своих заявок	
1.78	25.08.2026	Уточнено, что заблокированным и архивным учётным записям уведомления не отправляются; описан возврат с экрана сбоя на упавшую страницу; обновлены количественные показатели	
1.79	25.08.2026	В конвейере сборки описаны проверка предельного размера файлов исходного кода и проверка объёма стартовой загрузки интерфейса	
1.80	25.08.2026	Перечень разделов, где поиск раскрывает карточку, приведён поимённо; описаны вкладка чёрного списка в адресе перехода, расширение показа в реестрах и возврат доставки уведомлений после снятия блокировки	
1.81	26.08.2026	Описана подстановка в бланк сведений соседних вложений заявки - материальных ценностей и транспорта, и то, что строки непринятого дополнения в бланк не попадают	
1.82	29.08.2026	Описана сверка ключа шифрования при запуске: подмена ключа останавливает запуск, данные остаются нетронутыми	
1.83	14.10.2026	Актуализированы сроки, пересылка, незакрытые отметки, хранение данных, загрузка страниц и показатели исходного кода; уточнены границы проверок.	
1.84	21.10.2026	Сверены изменения октября: текущие права и сессии, документы и согласия, архив, файлы-черновики, push, лимиты и поставка; уточнены числовые показатели.	
1.85	22.10.2026	Уточнена административная принадлежность списка незакрытых отметок и исправления учёта; обычные операции охранника отделены от административных.	
1.86	30.10.2026	Уточнены запуск, продолжение, восстановление и применимость обучения; добавлены ролевые учебные сцены. Описана автоматическая доставка трёх образов стенда одной ревизии и разграничены проверки образов.	
1.87	30.10.2026	Описан ограниченный контроль действий в обучении для раздела «Доступные мне» и компонента отметки исполнения; уточнены границы автоматической проверки покрытия.	

Продолжение таблицы И.1

Версия	Дата	Содержание изменения	Внёс
1.88	01.11.2026	Уточнён запуск обучения при одном и нескольких доступных турах; обновлены количественные показатели кода и проверок.	
1.89	01.11.2026	Уточнена загрузка редко используемых окон; обновлены количественные показатели после улучшения клавиатурной навигации.	
1.90	01.11.2026	Описано управление уведомлениями с клавиатуры; обновлены показатели после улучшения уведомлений и справочников.	
1.91	05.11.2026	Уточнены транзакции заявок, бюджеты операций и состава, восстановление подачи, устойчивые фоновые задания, обновление данных, проверка документов, журналы и поставка проверенных образов; добавлены актуальное представление уведомлений и общий допуск тел запросов.	
1.92	10.11.2026	Описаны встроенные руководства принимающего и согласующего и правила доступа к ним.	

Окончание таблицы И.1

Версия	**Дата**	**Содержание изменения**	**Внёс**